

INTERNES KONTROLLSYSTEM (DIENSTLEISTUNGSBEZOGEN)

VERSION	10
DATUM	25.01.2022
AUTOR	Andreas Bachmann, Milan Naybzadeh, Michael Seefried
VERTRAULICHKEIT	Vertraulich
EMPFÄNGER	Mitarbeiter Adacor Group und freigegebene externe Personen
SEITENZAHL	58

Inhalt

1. Dokumenteninformationen	5
1.1 Dokumenten-Code	5
1.2 Freigabe.....	5
1.3 Ansprechpartner	5
2. Einleitung	5
2.1 Ziel und Umfang	5
2.2 Anwendung	6
2.3 Unternehmensbeschreibung	9
2.3.1 Facts.....	9
2.3.2 Finanzen & Ziele.....	10
2.3.3 Organisation	10
2.3.4 Erläuterung TIER Klassen.....	13
2.3.5 Internetanbindung.....	14
2.4 Vorgehensweise	14
2.4.1 Grundstruktur.....	14
2.4.2 Kriterien, Kontrollziele und Kontrollen.....	15
2.4.3 Korrespondierende Kontrollen beim auslagernden Unternehmen.....	15
3. Kontrollumfeld - KU	16
3.1 Verständnis.....	16
3.2 Ethische Werte - KU-ETH.....	16
3.3 Philosophie und Geschäftsgebaren des Managements KU-PHI	17
3.4 Organisationsstruktur KU-ORG	17
3.5 Grundsätze der Personalpolitik KU-PER.....	18
3.6 Qualitätsmanagement KU-QMA.....	19
3.7 Rechtliche und regulatorische Rahmenbedingungen KU-REG.....	20
4. Risikobeurteilung – RB	22
4.1 Verständnis.....	22
4.2 Betriebliche Risikobeurteilung RB-BET.....	23

4.3 Regeleinhaltung RB-REV	24
4.4 Veränderungsmanagement	25
5. Kontrollaktivitäten auf Prozessebene - KA	26
5.1 Verständnis.....	26
5.2 Service Design	26
5.2.1 Service Level Management KA-SLM	27
5.2.2 Capacity Management KA-CAP	27
5.2.3 IT Service Continuity Management KA-SCM.....	29
5.2.4 Information Security Management KA-ISM.....	32
5.2.5 Availability Management KA-AVM.....	36
5.2.6 Supplier Management - KA-SUP	38
5.3 Service Transition	40
5.3.1 Change Management - KA-CHA.....	40
5.3.2 Service Asset and Configuration Management KA-CON.....	41
5.4 Service Operation.....	42
5.4.1 Incident Management - KA-INC	42
5.4.2 Request Fulfillment - KA-RQF	44
5.4.3 Problem Management KA-PRM.....	45
5.4.4 Access Management - KA-ACM.....	46
6. Information und Kommunikation - IK-INF	47
6.1 Verständnis.....	47
6.2 Zeitnahe, zuverlässige und relevante Informationen - IK-INF.....	48
6.3 Kommunikation von Informationen - IK -KOM.....	49
7. Überwachung des internen Kontrollsystems - ÜW	50
7.1 Verständnis.....	50
7.2 Überwachung und Beurteilung von Kontrollen - ÜW-PRF	51
7.3 Korrigierende Maßnahmen - ÜW-KMA.....	52
Anhang A Referenzlisten zu Standards 2021	53
COBIT5	53

IDW-RS-FAIT-1	55
VDA ISA (TISAX)	56
Annex A der ISO27001:2015	57
Anhang B Änderungen zur letzten Version 2021	58

1. Dokumenteninformationen

1.1 Dokumenten-Code

IKS-DL

1.2 Freigabe

Die vorliegende Richtlinie in der Version 10 ist geprüft und freigegeben am 25.01.2022 durch die Ansprechpartner in Abschnitt 1.3.

1.3 Ansprechpartner

Andreas Bachmann
Geschäftsführer (CEO)

Patrick Fend
Geschäftsführer (CTO)

Thomas Wittbecker
Geschäftsführender Gesellschafter (GG)

2. Einleitung

2.1 Ziel und Umfang

Dieses Dokument beschreibt das dienstleistungsbezogene Interne Kontrollsystem (nachfolgend IKS) der Adacor Hosting GmbH (nachfolgend Adacor) im Rahmen der Erbringung von Cloud- und Hosting-Leistungen für die Kunden von Adacor und unterliegt der Prüfung nach IDW PS 951.

Die IKS-Beschreibung und der zugehörige IDW PS 951 Prüfbericht sollen den Wirtschaftsprüfern der Kunden von Adacor hinreichende Informationen bereitstellen, damit diese den IKS-Aufbau und die implementierten Kontrollen nachvollziehen und im Rahmen ihrer Prüfungshandlungen für den Kunden berücksichtigen können. Es soll klar dargestellt werden, welche Kontrollen durch Adacor erbracht werden und welche weiteren Kontrollen durch den Kunden separat durchzuführen, beziehungsweise bei Adacor zu beauftragen sind.

2.2 Anwendung

Der Geltungsbereich der vorliegenden IKS-Beschreibung als Grundlage für die Prüfung nach IDW PS 951 umfasst die durch Adacor erbrachten Dienste Complex / Enterprise Hosting, Cloud Hosting, Managed Services und Hosting Infrastruktur in der eigenen Infrastruktur. Auf Basis dieser Dienste erbringt Adacor individuelle Hosting Leistungen, bei denen für jeden Kunden auf Projektbasis eine individuelle Serverinfrastruktur aufgebaut und betrieben wird.

Die genaue Ausgestaltung dieser Kundeninfrastruktur wird mit dem Kunden zusammen erarbeitet, geplant und dann durch Adacor beschafft, aufgesetzt, betrieben und betreut. Der Systembetrieb erfolgt in Rechenzentrumsflächen, die von Adacor angemietet sind.

Der Dienstleistungsumfang der Dienste bestimmt sich im Detail wie folgt:

Cloud Hosting

- Konzeption von individuellen Public, Private und Hybrid Cloud Lösungen
- Aufbau und Betrieb von vServern und Cloud Services auf Basis einer Virtualisierungsinfrastruktur

Complex Hosting / Enterprise Hosting

- Konzeption projektspezifischer Serverinfrastrukturen
- Aufbau und Betrieb von Servern in angemieteten Rechenzentrumsflächen
- Beschaffung, Austausch, Einbau und Betreuung von Servern und Stagesystemen

Managed Services

- Setup und Management der Server auf den Ebenen Betriebssystem- und Plattform-Anwendungen (Datenbanken, Programmiersprachen, Systembibliotheken)
- Überwachung der Server und Dienste mithilfe des Monitorings
- Implementierung, Betrieb und Überwachung von Backupkonzepten
- Bereitstellung eines Service Desks und Bereitschaftsdienstes
- Übernahme der Betriebsverantwortung für komplette Umgebungen
- Individuelle Betreuung und Weiterentwicklung von Umgebungen

Hosting Infrastruktur

- Aufbau und Betrieb einer Netzwerkinfrastruktur in Rechenzentrumsflächen, die von der Adacor angemietet sind
- Beschaffung, Austausch, Einbau und Betreuung von Racks, Netzwerk- und nicht aktiven Stromversorgungskomponenten
- Firewall- und Netzwerkmanagement
- Anbindung an das Internet über die Adacor Netzwerkinfrastruktur
- Aufbau und Betrieb einer Monitoring-Infrastruktur
- Aufbau und Betrieb einer Backupinfrastruktur

Abgrenzung

Hinsichtlich der Prüfung nach IDW PS 951 ist zu beachten, dass Adacor selbst keine aktive direkte Verarbeitung von rechnungslegungsrelevanten Daten vornimmt, sondern technische Ressourcen bereitstellt auf denen Anwendungen zur Verarbeitung ebensolcher Daten betrieben werden können.

In verschiedenen Bereichen ist Adacor auf korrespondierende Kontrollen seitens des auslagernden Unternehmens (Kunden) angewiesen. Diese werden in 2.4.3 ausführlich beschrieben. Explizit nicht abgedeckt in der IKS-Beschreibung und separat zu betrachten sind Kontrollziele und Kontrollen auf Ebene der Anwendungen, die auf den bereitgestellten Servern sowie auf Server, die nicht in der Adacor-Infrastruktur betrieben werden und auf der Ebene des Rechenzentrumsbetriebes.

Die Anwendungsebene sowie fremde Server entziehen sich regelmäßig der Kontrolle und Verantwortung von Adacor und liegen komplett beim Kunden, oder von diesem weiter beauftragte Dienstleister.

Im Rahmen des Rechenzentrumsbetriebes mietet Adacor in sich geschlossene Rechenzentrumsflächen und überträgt die Aufgabe des Rechenzentrumsbetriebes damit an sorgfältig ausgewählte und erfahrene Dienstleister. In dieser IKS-Beschreibung werden hierzu Kontrollen zur Dienstleisterauswahl und -überwachung beschrieben (Carve-Out Methode).

Rechenzentrumsdienstleister erbringen für Adacor folgende Leistungen:

- Housing (Bereitstellung von RZ-Flächen)
- Facility Management
- Physikalische Zutrittssicherheit

- Brandschutz
- Kühlung und Klimatisierung
- Stromversorgung und USV
- Verkabelung außerhalb der Mietflächen von Adacor

Betrachtet werden in diesem Dokument ausschließlich die Kontrollen der Adacor Hosting GmbH. Nicht betroffen sind die Konzernverbundenen Filoo GmbH und Exolink GmbH.

Geltungsbereich IKS-Beschreibung

Die nachfolgende Grafik beschreibt den oben beschriebenen Geltungsbereich und die Abgrenzung der Dienstleistungen der IKS-Beschreibung, sowie die Richtung und Ebenen, in denen diese aufeinander aufbauen, um den Business Service für den Kunden bereit zu stellen.

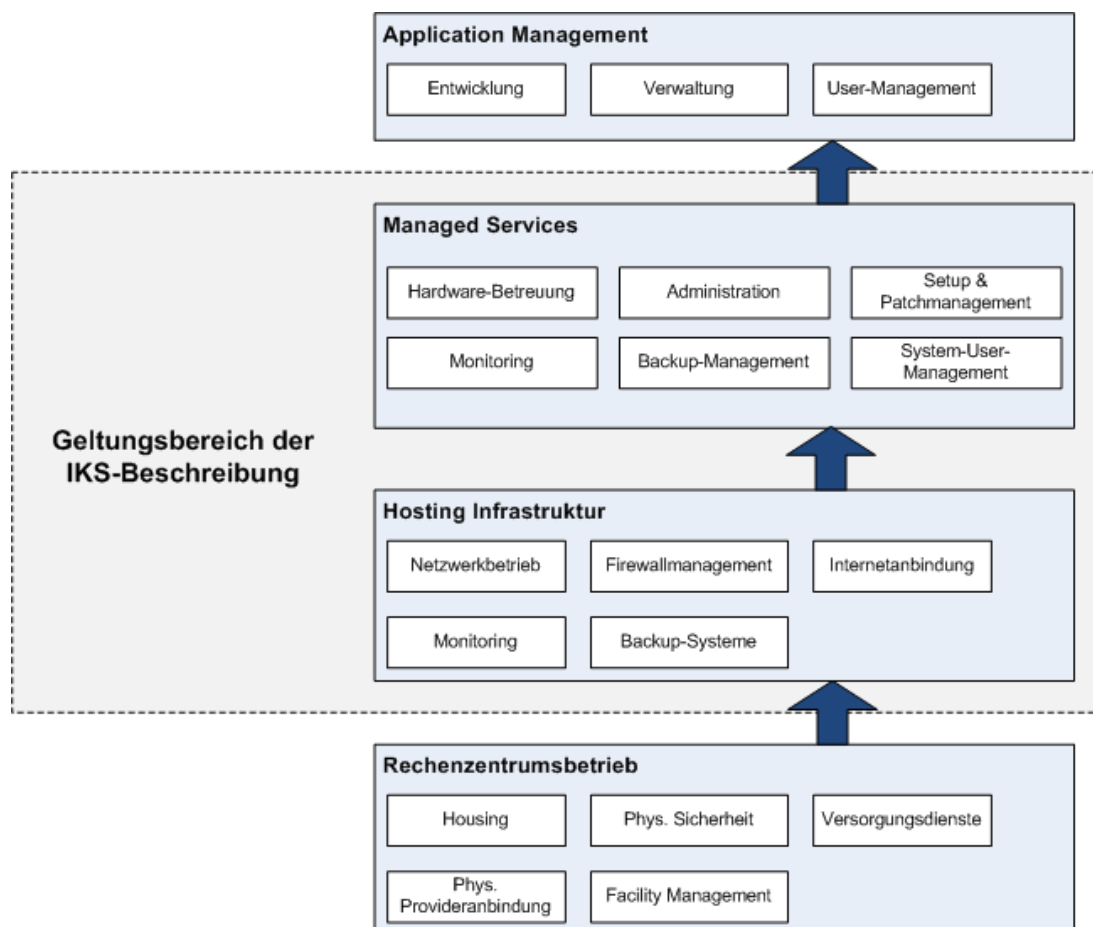


Abbildung 1 Geltungsbereich der IKS-Beschreibung

2.3 Unternehmensbeschreibung

Adacor Hosting GmbH ist ein gesellschaftergeführtes, von Investoren unabhängiges Unternehmen und bietet seit 2003 individuelle und sichere Hosting-Lösungen für komplexe, internetnahe Projekte.

Egal ob Internet- / Intranet-Anwendungen oder spezielle Applikationen wie Marketing-Sites, Portale, Projektmanagement- oder Client-Server-Plattformen, Adacor entwickelt für seine Kunden individuelle projektbezogene Hostinglösungen, welche die spezifischen Anforderungen des Projektes an Verfügbarkeit, Performance, Skalierbarkeit, Sicherheit und Management erfüllen.

Die Projektbandbreite erstreckt sich dabei vom einzelnen vServer für Kampagnen bis zur komplexen Architektur aus hunderten dedizierten Servern und spricht damit große Mittelständler und Konzerne an. Das volle Potenzial von Adacor wird dabei dort ausgespielt, wo Adacor von der Konzeption bis zum 24/7 Betrieb das Service Management übernimmt bzw. dort eng integriert ist.

Adacor hat in Frankfurt an zwei verschiedenen RZ-Standorten (NTT & Interxion) eigene RZ-Räume gemietet, in denen die Server und IT-Systeme betrieben werden. Die technische Betreuung erfolgt vom Network Operation Center (NOC) in Offenbach aus. Marketing, Buchhaltung und Verwaltung sind am Stammsitz in Essen angesiedelt.

Der Hosting-Betrieb betreut über 2.700 Hosts mit 31.000 Diensten und erfolgt 24/7 an 365 Tagen im Jahr. Außerhalb der Bürozeiten steht eine Rufbereitschaft zur Verfügung.

Kernzielmarkt von Adacor sind große Mittelständler, Organisationen und Konzerne. So betreibt Adacor aktuell Hosting-Services für z.B. E.ON, Heraeus, Suzuki, GLS Bank und Bürkert.

2.3.1 Facts

- > Rechtsform: GmbH
- > Gründung: 2003
- > Geschäftsführer: Andreas Bachmann, Thomas Wittbecker, Patrick Fend
- > Branche: Cloud- und Hosting-Services
- > Stammkapital: 4.000.000 EUR (Stand 12/2021)
- > Umsatz 8,8 Mio. (Stand 12/2021)
- > Mitarbeiter: 73,9 (Stand 12/2021)

2.3.2 Finanzen & Ziele

Als Dienstleister kann Adacor nur dann langfristig hochwertige, verlässliche und sichere Leistungen erbringen und ein stabiler Partner sein, wenn Adacor finanziell auf gesunden Füßen stehen.

Um auch nach außen zu dokumentieren, dass Adacor finanziell eine konservative langfristige Strategie verfolgt, wird ein großer Teil des Eigenkapitals als haftendes Stammkapital (zurzeit 4.000.000 Euro) ausgewiesen, die Bilanzen jährlich von einem unabhängigen Wirtschaftsprüfer testiert, Adacor einem jährlichen Bonitätsaudit für das Crefozert der Creditreform unterzogen und Haftungsrisiken konsequent durch entsprechende Versicherungen abgesichert.

2.3.3 Organisation

2.3.3.1 Standorte

Adacor gliedert sich in zwei Unternehmensstandorte sowie zwei Rechenzentrumsstandorte auf.

Standort Verwaltung (Essen)

Am Standort Essen befinden sich die Geschäftsbereiche und Verantwortlichkeiten der Verwaltung, Buchhaltung, Marketing und kaufmännische Geschäftsführung.

Adacor Hosting GmbH
Verwaltung
Emmastr. 70a
45130 Essen

Standort NOC (Offenbach am Main)

Das wesentliche operative Geschäft erfolgt vom NOC in Offenbach aus. Hier sind die Bereiche Operations, Information & Compliance, Vertrieb, Development und Infrastruktur angesiedelt.

Adacor Hosting GmbH NOC (Network Operation Center)
Kaiserleistr. 8a
63067 Offenbach am Main

Standort NTT Rechenzentrum (Frankfurt am Main)

Adacor hat insgesamt 3 Räume bei NTT Global Data Centers EMEA GmbH (NTT) angemietet. Bis 2020 firmierte NTT noch unter dem Namen e-shelter GmbH. NTT betreibt in Frankfurt ein Tier 3+ Rechenzentrum. NTT stellt die RZ-Räume inklusive Versorgungsdiensten, Zutrittsschutz und Facility Management bereit. Der Innenausbau mit Verkabelung, Racks und Arbeitsmitteln erfolgt dann durch Adacor. Bei NTT handelt es sich um den primären RZ-Standort von Adacor für Kundenprojekte. Die NTT Global Data Centers EMEA GmbH verfügt über eine Zertifizierung nach ISO 27001 auf Basis IT-Grundschutz durch das Bundesamt für Sicherheit in der Informationstechnik.

Frankfurt 1 Data Center
NTT Global Data Centers EMEA GmbH
Eschborner Landstraße 100
60489 Frankfurt am Main

Abbildung 2

ISO 27001-Zertifikat auf der Basis des IT-Grundschutzes



Standort interxion Rechenzentrum (Frankfurt am Main)

Interxion betreibt in Frankfurt ein Tier 3 Rechenzentrum. Adacor hat dort einen eigenen Raum angemietet. Interxion stellt den RZ-Raum inklusive Versorgungsdiensten, Zutrittsschutz und Facility Management bereit. Der Innenausbau mit Verkabelung, Racks und Arbeitsmitteln erfolgt dann durch Adacor. Bei Interxion handelt es sich um den sekundären RZ-Standort von Adacor. Das InterXion Rechenzentrum verfügt über ein zertifiziertes Informationssicherheitsmanagement nach ISO 27001 sowie ein zertifiziertes Business Continuity Management System nach ISO 22301. Zudem hält es nachweislich durch den TÜV geprüft den Payment Card Industry Data Security Standard (PCI DSS) ein.

Interxion Deutschland GmbH
Hanauer Landstraße 298
60314 Frankfurt am Main



Abbildung 3 ISO27001-Zertifizierungslogo von interxion (bsi.-Cert Nr. IS 537141)

2.3.3.2 Organisationsstruktur



Abbildung 4 Organigramm Adacor Hosting GmbH

Die im Rahmen dieser IKS-Beschreibung relevanten Organisationseinheiten entsprechend der Organisationsstruktur sind:

Management: Das Management trägt die Verantwortung für die Einhaltung der ordnungsgemäßen Geschäftsführung wozu auch die ordentliche Umsetzung und der Betrieb des Internen Kontrollsystems zählt.

People & Culture: Die Abteilungen People Operations verantwortet die strategische Personalplanung des Unternehmens. Dazu gehört es die angemessene Auswahl, Einstellung, Entwicklung und Zufriedenheit der Mitarbeitenden herzustellen, beizubehalten und auszubauen.

Customer Operations: Im Bereich Customer Operations werden alle Leistungen rund um die Betreuung, Setup und Wartung der Server, vServer und Managed Services auf (v)Servern erbracht. In diesen Bereich fällt auch der Service-Desk, Incident- und Change-Management.

Governance: Die Bereiche Information Security Management, Compliance und Interne Revision setzen sich übergreifend aus Mitgliedern der verschiedenen anderen Organisationseinheiten zusammen und steuern zentral die Konzeption, Überwachung und Umsetzung sämtlicher sicherheits- und notfallrelevanter Tätigkeiten.

2.3.4 Erläuterung TIER Klassen

Elementar für die Einhaltung der SLAs gegenüber den Kunden von Adacor ist die ununterbrochene Verfügbarkeit der Stromversorgung. Der Redundanzaufbau und die erwarteten Verfügbarkeiten werden nach so genannten TIER Klassen unterteilt. Für Adacor kommen grundsätzlich nur Rechenzentren ab Klasse TIER 3 aufwärts in Betracht.

		Downtime per anno	Verfügbarkeit
T1	<i>einfadig, ohne Redundanz</i>	DTPA 28,8 h	99,67 %
T2	<i>einfadig, Redundanz nach n+1</i>	DTPA 22,0 h	99,74 %
ADACOR nutzt ausschließlich T3 + T4 Verbindungen			
T3	<i>zweifadig, 2 x n, A-B Versorgung</i>	DTPA 1,6 h	99,98 %
T4	<i>zweifadig, jeder Pfad n+1 Redundanz</i>	DTPA 0,8 h	99,995 %

Abbildung 5 TIER Klassifizierungen

2.3.5 Internetanbindung

Um einen dauerhaft schnellen und hochverfügbaren Zugriff auf die von Adacor gehosteten Systeme zu ermöglichen, haben wir Anbindungen zu mehreren Carriern bzw. Carrier-Pools gemietet und verfügen so über jeweils redundante 10Gbit bzw. 1Gbit Anbindungen an alle zentralen Netzaustauschknoten. Zusätzlich sind unsere beiden Rechenzentrumsstandorte untereinander über Glasfaser miteinander verbunden, um Notfall-, Backup- oder Katastrophenszenarios abbilden zu können.

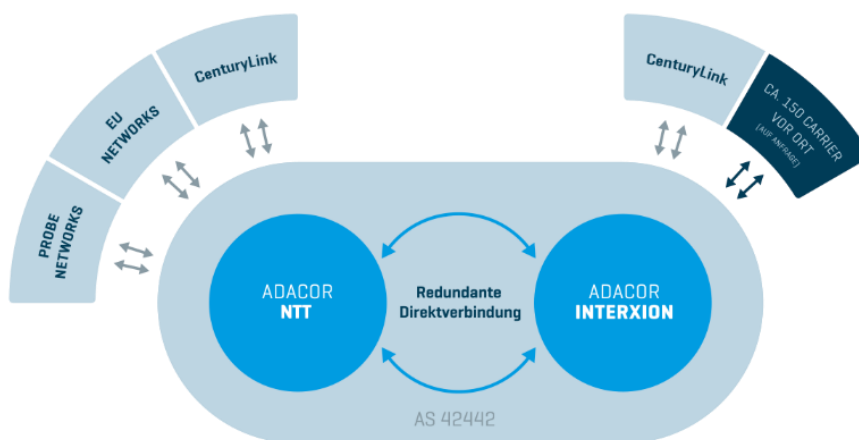


Abbildung 6 Internetanbindung

2.4 Vorgehensweise

Das dienstleistungsbezogene IKS von Adacor orientiert sich an den international anerkannten Standards COSO und COBIT. Das IKS ist zudem an das Informationssicherheits-Managementsystem (ISMS) von Adacor angebunden und verwendet daher auch Vorgaben und Herangehensweisen der ISO 27001 und des IT-Grundschutzes.

2.4.1 Grundstruktur

Die vorliegende Beschreibung des IKS orientiert sich vom Aufbau her an den fünf COSO Komponenten und besteht aus den Bereichen:

1. Kontrollumfeld
2. Risikobeurteilung
3. Kontrollaktivitäten auf Prozessebene
4. Information und Kommunikation
5. Überwachung des internen Kontrollsystems

In der Beschreibung des IKS befinden sich unternehmensbezogene Kontrollen in den Punkten Kontrollumfeld, Risikobeurteilung, Information und Kommunikation und Überwachung sowie prozessbezogene Kontrollen im Punkt Kontrollaktivitäten. Innerhalb jeder der COSO Komponenten wird zunächst das Verständnis von Adacor und der Bezug dieses Punktes hinsichtlich der Dienstleistungserbringung dargestellt und dann auf die entsprechenden Kontrollziele und Kontrollen (Maßnahmen) eingegangen.

2.4.2 Kriterien, Kontrollziele und Kontrollen

Entsprechend der Dienstleistungsbeschreibung greift Adacor bei den Kontrollzielen und Kontrollen primär auf Kriterienkataloge von COBIT 5 und ISO 27001:2015 zurück, sowie auf eigene Kontrollziele aus dem Risiko-Management der Adacor. Sofern passend, werden zudem die Kriterien des IDW RS FAIT 1 auf Grund der Dienstleistungsbeschreibung adressiert. Die Nummerierung erfolgt nach einem eigenen System. Im Bereich Kontrollaktivitäten auf Prozessebene erfolgt die Strukturierung der Prozesse anhand der von ITIL (IT Infrastructure Library) vorgegebenen Service Lifecyclephasen und Management-Prozesse.

Die Referenzierung der Kontrollziele und Kontrollen zu den jeweiligen Frameworks und Standards finden sich im Anhang A "Referenzlisten". In dieser Beschreibung des IKS befinden sich nur wesentliche Kontrollen, die ausschlaggebend für die Dienstleistungserbringung sind. Für die jeweiligen Zertifizierungen liegen darüber hinaus noch weitere Anwendbarkeitserklärungen (Statement of Applicabilities) vor, die die zur Umsetzung dieser Standards weiteren nötigen und umgesetzten Maßnahmen erläutern.

Die nachfolgend beschriebenen Kontrollziele und Kontrollen unterliegen der Prüfung nach IDW PS 951 und sollen die getroffenen Maßnahmen für die Kunden der Adacor transparent machen, damit diese ergänzend in die internen Kontrollsysteme der Kunden von Adacor übernommen werden können.

2.4.3 Korrespondierende Kontrollen beim auslagernden Unternehmen

Die Dienstleistungen von Adacor sind so aufgebaut, dass bestimmte Kontrollen und Verfahren in den verschiedenen Prozessen und Bereichen durch den Kunden (auslagerndes Unternehmen) erbracht werden müssen und in dessen Verantwortung liegen. Die Kontrollen von Adacor entfalten in diesen Fällen nur dann ihre volle Wirksamkeit, wenn die entsprechenden korrespondierenden Kontrollen beim Kunden ebenfalls implementiert sind. Die korrespondierenden Kontrollen befinden sich bei den jeweiligen COSO-Bereichen und Prozessen unterhalb der Kontrollziele und Kontrollen von Adacor.

3. Kontrollumfeld - KU

3.1 Verständnis

Das Kontrollumfeld stellt nach dem Verständnis von Adacor die Grundlage und den Rahmen für alle nachfolgenden Prozesse, Ziele und Maßnahmen dar. Es beinhaltet grundsätzliche Einstellungen, Führungsverhalten, Vorgaben und Visionen der Geschäftsführung im Hinblick auf das IKS.

3.2 Ethische Werte - KU-ETH

Die Geschäftsführung von Adacor hat eindeutige Vorgaben zu ethisch korrektem und integrem Verhalten definiert und diese in einem Verhaltenskodex sowie fachbezogenen Leit- und Richtlinien dokumentiert, die über das Intranet abgerufen werden können.

Die Verbreitung und Kommunikation dieser Werte erfolgt in Form von integrierten Abläufen und Prozessen im Rahmen der Mitarbeiterführung durch Unterweisungen, aktives Vorleben, Integration der Mitarbeiter in Entscheidungsprozesse, Transparenz und Coaching von Mitarbeitern mit Führungsverantwortung durch die Geschäftsführung.

Den Mitarbeitern ist bekannt, wie Fehlverhalten gegen die ethischen Grundsätze geahndet wird. Mitarbeiter werden ermutigt sich mit Vorfällen direkt an die Geschäftsführung zu wenden.

Aus diesem Bereich leiten sich folgende wesentliche Kontrollziele und Maßnahmen ab:

KONTROLLZIEL	MAßNAHME
KU-ETH-001 - Ethische Werte und erwartetes Verhalten Ethische Werte und Verhaltensvorgaben sind dokumentiert, kommuniziert und werden eingehalten.	M1 Verhaltensvorgaben und Leitwerte sind im Verhaltenskodex, der IS-Leitlinie und der Richtlinie Personalmanagement von Adacor schriftlich definiert und im XPMS veröffentlicht.
	M2 Mitarbeitende werden mindestens jährlich auf den Verhaltenskodex und die IS-Leitlinie von Adacor verpflichtet.
	M3 Adacor berichtet öffentlich über durchgeführte Maßnahmen und deren Fortschritt zur Umsetzung im Rahmen der Corporate Social Responsibility.
	M4 Zur Meldung von Verstößen wurde ein Prozess zum Whistleblowing etabliert über den Mitarbeitende Verstöße gegen die Verhaltensvorgaben möglichst anonymisiert melden können.

3.3 Philosophie und Geschäftsgebaren des Managements KU-PHI

Als gesellschaftergeführtes Unternehmen wird Adacor unternehmerisch mit einem langfristigen Horizont auf nachhaltiges Wachstum und finanzielle Stabilität geführt. Kernelemente der unternehmerischen Philosophie (Werte) der Geschäftsführung sind die Generierung nachhaltigen Wachstums, Etablierung als verlässlicher Partner für Mitarbeitende und Kunden, Schonung von Umweltressourcen sowie Beibehaltung der finanziellen Stabilität und Unabhängigkeit.

Für zeitnahe strategische und operative Entscheidungsfindung und Informationsverteilung hat Adacor geeignete Strukturen in Form von Management-, Strategie- und Teammeetings sowie Tools und Prozessen geschaffen, die gleichzeitig umfassende Chancen- und Risikoanalysen ermöglichen.

Zur Unterstützung einer einfachen und bidirektionalen Informationsverteilung, wurde ein Umfeld geschaffen, in dem sich alle Mitarbeitenden mit jedem Thema jederzeit an einen Leiter oder Geschäftsführer wenden können.

Aus diesem Bereich leiten sich folgende wesentliche Kontrollziele und Maßnahmen ab:

KONTROLLZIEL	MAßNAHME
KU-PHI-001 - Gewissenhaftigkeit des Managements Das Management zeigt Gewissenhaftigkeit, Vorsicht und Weitsicht hinsichtlich der eingegangenen Risiken, Geschäftsgebaren und strategischen Entscheidungen.	M1 Es finden regelmäßige Management-, Security- und Controlling-Meetings statt, in denen Entscheidungen, Risiken, Chancen und Situationen bewertet und entsprechende Maßnahmen beschlossen werden.
	M2 Die Geschäftsführung adressiert persönlich regelmäßig wichtige Themen an alle Mitarbeitenden.
	M3 Die Geschäftsführung veröffentlicht jährlich Vision, Mission und Strategie von Adacor.

3.4 Organisationsstruktur KU-ORG

Fachaufgaben und Verantwortlichkeiten für Services und Systeme sind in einer einfachen und effizienten Struktur aufgebaut (siehe 2.3.3 Organisation) und ermöglichen so eine hohe Servicequalität und Reaktionsfähigkeit.

Die gegenüber dem Kunden sichtbar erbrachten Services (Cloud und Hosting) werden durch den Bereich Customer Operations erbracht, der wiederum seine Leistung auf Basis der intern zur Verfügung gestellten Services der Bereiche Network Operations und Technology Operations (u.a. Netzwerkmanagement, Backup, Monitoring) erbringt.

Jeder der relevanten Fachbereiche ist direkt einem verantwortlichen Geschäftsführer zugeordnet und berichtet diesem. Dadurch sind effiziente Kommunikationswege geschaffen und die Geschäftsführung so nah am Tagesgeschäft, dass notwendige Anpassungen bei Kapazitäten und Prozessen zeitnah in die strategischen Überlegungen der Geschäftsführung einfließen können.

Aus diesem Bereich leiten sich folgende wesentliche Kontrollziele und Maßnahmen ab:

KONTROLLZIEL	MAßNAHME
KU-ORG-001 - Leistungsfähige Serviceerbringung Die Organisationsstruktur, Personalausstattung und klaren Verantwortlichkeiten ermöglichen eine leistungsfähige, qualifizierte und flexible Serviceerbringung und Sicherstellung der Kunden-SLAs.	M1 Die Organisationsstruktur zur Serviceerbringung von Adacor ist so aufgebaut, dass sie eine klare Zuordnung von Verantwortlichkeiten zu Themen darstellt.
	M2 Strukturen und Prozesse werden kontinuierlich verbessert um Abläufe, Kapazitäten und Effizienz zu steigern.
	M3 Zur Qualitätsförderung werden Prozesse an Best-Practices Ansätzen wie ITIL ausgerichtet.
KU-ORG-002 - Kommunikation und Kontrolle Die Struktur ermöglicht vertikalen und horizontalen Kommunikations- und Informationsfluss sowie Berichterstattung, Prüf- und Kontrollmöglichkeiten.	M1 Vertikale Verantwortungs- und Berichtswege sind implementiert und dediziert einem Geschäftsführer zugeordnet.
	M2 Unterstützung einer offenen und direkten Kommunikation und Feedbacks durch Feedbackgespräche.

3.5 Grundsätze der Personalpolitik KU-PER

Im Bereich der IT-Serviceerbringung setzt Adacor ausschließlich qualifiziertes und geeignetes Personal ein. Die Anforderungen an Positionen und Verantwortlichkeiten sind in Form von Stellenprofilen definiert. Mitarbeitende verfügen über eine entsprechende fachspezifische Ausbildung oder langjährige Berufserfahrung. Die Qualifikation von Mitarbeitenden wird vor Beginn, während der Anstellung sowie bei Wechsel der Verantwortlichkeit überprüft. Das Vorgehen bei Beginn, Beendigung oder Änderung einer Anstellung ist in der Richtlinie Personalmanagement vorgegeben und wird über festgelegte Prozesse abgebildet.

Um kontinuierlich eine hohe Servicequalität sicherstellen zu können, erhalten Mitarbeitende Schulungs- und Weiterbildungsmöglichkeiten in relevanten Fachthemen. Die grundlegend gewünschten Weiterbildungen und Unterweisungen sind in Form eines Schulungsprogramms schriftlich definiert. Das Schulungsprogramm wird von der Geschäftsführung in Abstimmung mit People Operation gepflegt.

Einstellung, Beförderung, Entlassung und Beurteilung sind in Form von Richtlinien und Prozessen definiert und in den Führungsebenen kommuniziert.

Ein umfassendes Leistungspaket, Benefits und eine offene Kommunikation von Unternehmenszahlen und -zielen schaffen ein motivierendes und leistungsförderndes Umfeld, das es den Mitarbeitenden ermöglicht, sich auf Ihre Aufgaben bei Adacor zu fokussieren.

Ein Gesamtwerk aus Regelungen, Richtlinien und Prozessen schafft für die Mitarbeitenden einen verbindlichen Rahmen, in dem diese sich bewegen können, sowie Sicherheit und Klarheit hinsichtlich gewünschtem und erlaubtem Verhalten sowie den Konsequenzen bei Nichteinhaltung.

Aus diesem Bereich leiten sich folgende wesentliche Kontrollziele und Maßnahmen ab:

KONTROLLZIEL	MAßNAHME
KU-PER-001 - Grundsätze Personalpolitik Einheitliche Grundsätze des Personalmanagements sind definiert und kommuniziert.	Bis 31.12.2020 M1 Einstellung, Veränderung und Beendigung von Arbeitsverhältnissen sind in der Richtlinie Personalmanagement vorgegeben und erfolgen durch Prozesse formalisiert und strukturiert.
	Seit 01.01.2021 M1 Einstellung, Veränderung und Beendigung von Arbeitsverhältnissen sind in der Richtlinie Personalmanagement vorgegeben und erfolgen formalisiert und strukturiert mithilfe von Workflows.
	M2 Einheitliche Prozesse zur Maßregelung sind definiert und dokumentiert.
KU-PER-002 - Fachwissen zur Serviceerbringung Das erforderliche Fachwissen zur qualifizierten Serviceerbringung ist in der Adacor vorhanden.	M1 Stellenbeschreibungen beinhalten die notwendigen und geforderten Qualifikationen. Zusatzqualifikationen für bestimmte Tätigkeiten sind schriftlich im Schulungsprogramm definiert.
	M2 Das Management pflegt ein Schulungsprogramm, das notwendige und gewünschte Schulungen und Weiterbildung für die verschiedenen Geschäftsbereiche und Tätigkeitsbilder enthält.

3.6 Qualitätsmanagement KU-QMA

Adacor hat einen hohen Anspruch in Bezug auf SLA Einhaltung und Qualität der Serviceerbringung. Um diesen Anspruch gerecht werden zu können, wurden entsprechende Qualitätsversprechen formuliert und extern wie intern kommuniziert.

Zur Sicherung eines gleichbleibend hohen Qualitätsstandards wurde ein umfassendes Qualitätsframework aus Richtlinien, Betriebshandbüchern, Prozessen, Tools und Automatisierungen geschaffen, und dauerhaft erhebliche Ressourcen in den weiteren Ausbau dieses Frameworks investiert. Ein elementarer Bestandteil des Qualitätsmanagements ist für uns die Orientierung an international anerkannten Standards. Im Bereich der Dienstleistungserbringung sind dies für vor allem ITIL, COBIT, ISO 20000, die BSI IT Grundschutzstandards und ISO 27001. Die genannten Standards dienen uns als Vorlage für unsere eigenen Prozesse und Vorgehensweisen und finden daher auch bei der Konzeption unserer Tools des XPMS Berücksichtigung.

Richtlinien und Konzepte werden mindestens jährlich Revisionen unterzogen, geschult und unterwiesen.

Aus diesem Bereich leiten sich folgende wesentliche Kontrollziele und Maßnahmen ab:

KONTROLLZIEL	MAßNAHME
KU-QMA-001 – Qualitätsversprechen Der Anspruch an die Qualität der Serviceerbringung wurde in Form von Qualitätsversprechen definiert und kommuniziert.	M1 Qualitätsziele sind im Adacor Verhaltenskodex definiert und an Mitarbeiter sowie Kunden kommuniziert.
KU-QMA-002 - Qualitätsmanagement Ein Qualitätsmanagementframework aus Prozessen und Tools ist implementiert und orientiert sich an internationalen Standards.	M1 Verfahren, Strukturen und Tätigkeiten werden dokumentiert und durch Prozessdefinitionen, Checklisten und Tools unterstützt. Strukturen und Prozesse werden i.d.R unter Berücksichtigung von Best Practice Ansätzen (z.B. internationale Standards ISO 27001 und ITIL) implementiert.

3.7 Rechtliche und regulatorische Rahmenbedingungen KU-REG

Als Cloud- und Hosting-Dienstleister fällt Adacor für seine Kunden in den Bereich Outsourcing und unterliegt damit in der Regel denselben regulatorischen Anforderungen wie ebendiesen Kunden. Adacor sieht es daher als eine der Kernaufgaben an, im Bereich Compliance proaktiv für und mit den Kunden Lösungen zu schaffen, die deren Compliance-Anforderungen und -Projekte bestmöglich unterstützen. Entsprechend unserem Dienstleistungsportfolio gelten für Adacor zumindest die nachfolgenden gesetzlichen Regelungen:

- HGB (Grundsätze ordnungsmäßiger Buchführung)
- Datenschutz-Grundverordnung (EU) 2016/679 (DSGVO zum Schutz personenbezogener Daten)
- BDSG (Deutsches Gesetz zur Anpassung des Datenschutzrechts an die DSGVO)
- TKG (Fernmeldegeheimnis)
- SGB X (Sozialgeheimnis)

- KonTraG (Risikomanagement)
- IT-Sicherheitsgesetz (IT-Sicherheit)

Zur Berücksichtigung der Anforderungen zum Datenschutz hat Adacor eine Datenschutz- und Datensicherheitsorganisation, bestehend aus einem externen Datenschutzbeauftragten sowie der internen Abteilung Informationssicherheit & Compliance Management (ISM) implementiert.

Zur Reduzierung von Risiken wegen der Nichteinhaltung von anderen Gesetzen, Verträgen oder anderer Anforderungen, beobachtet die Abteilung ISM aktuelle relevante Vorgänge und leitet rechtzeitig Maßnahmen ein. Die Datenschutz- und Compliance-Organisation ist in das Informationssicherheitsmanagement von Adacor eingebettet.

Aus diesem Bereich leiten sich folgende wesentliche Kontrollziele und Maßnahmen ab:

KONTROLLZIEL	MAßNAHME
KU-REG-001 - Datenschutzorganisation Eine Datenschutzorganisation ist implementiert.	M1 Adacor hat eine Datenschutzorganisation implementiert, welche in einem zentralen Datenschutzkonzept festgehalten wurde, um den Mitarbeitern von Adacor eine Richtschnur hinsichtlich ihrer jeweiligen Verantwortungsbereiche sowie der jeweils einzuhaltenden Verfahren vorgibt.
	M2 Zur Sicherstellung der Einhaltung der datenschutzrechtlichen internen Regelungen sowie aller relevanten Gesetze und Vorschriften zum Schutz der Privatsphäre und personenbezogener Daten wurde ein Datenschutzbeauftragter bestellt.
	M3 Mitarbeiter von Adacor werden zum rechtskonformen Umgang mit personenbezogenen Daten unterwiesen und geschult.
	M4 Die allgemeinen technischen und organisatorischen Maßnahmen zur Gewährleistung der Datensicherheit werden zentral dokumentiert.
	M5 Adacor pflegt ein Verzeichnisse über Beschreibungen der Verarbeitungsprozesse bezüglich personenbezogener Daten in der Verantwortung von Adacor. Diese Prozesse erhalten eine Datenschutzfolgeabschätzung.
	M1 Die Abteilung Informationssicherheit und Compliance Management (ISM) beobachtet und prüft die aktuelle Rechtslage weiterer lokaler und internationaler Gesetze, Verträge und anderer externer Anforderungen, die von Adacor eingehalten werden müssen und leitet die weitere Implementierung ein. Die Tätigkeiten werden regelmäßig an die Geschäftsführung kommuniziert.

KU-REG-002 - IT-Compliance-Organisation Für die IT-Serviceerbringung relevante Anforderungen aus Gesetzen, Verträgen und anderen Vorschriften werden rechtzeitig erkannt und Maßnahmen zur Einhaltung ergriffen.	M2 Die Mitarbeiter werden regelmäßig über für sie bei der Service-Erbringung relevante Regelungen, wozu auch Korruptions- und Geldwäscheprävention gehört unterwiesen und zur Einhaltung dieser verpflichtet.
--	--

Korrespondierende Kontrollen beim auslagernden Unternehmen (Kunde):

- Der Kunde trägt die Verantwortung für die Einhaltung der Gesetze zum Datenschutz. Anforderungen an und Verfahrensanpassungen bei der Adacor sind im Rahmen einer Auftragsdatenverarbeitungsvereinbarung schriftlich zu definieren.
- Der Kunde trägt die Verantwortung für die Einhaltung und vor allem die frühzeitige Kommunikation weiterer externer gesetzlicher, aufsichtsrechtlicher oder anderer Anforderungen an die beauftragten Systeme. Anforderungen an und Verfahrensanpassungen bei der Adacor sind im Rahmen der Beauftragungen schriftlich zu definieren.

4. Risikobeurteilung – RB

4.1 Verständnis

Die Adacor ist grundsätzlich einer Vielzahl von Risiken ausgesetzt. Ein Risiko sehen wir hier als Gefährdung das die Erreichung unserer Unternehmensziele verhindern oder beeinträchtigen kann. Anlehnend an COSO betrachten wir Risiken in den drei Kategorien

1. Betrieblich
2. Berichterstattung
3. Regeleinhaltung

Kategorie 2 (Berichterstattung) findet in dieser IKS-Beschreibung keine Betrachtung. Zusätzlich zu den COSO-Kategorien betrachten wir Risiken in einer übergeordneten Management-Ebene im Rahmen des Veränderungsmanagements.

4.2 Betriebliche Risikobeurteilung RB-BET

Adacor ist grundsätzlich einer Vielzahl von Risiken ausgesetzt. Ein Risiko wird als Gefährdung gesehen, welches die Erreichung unserer Unternehmensziele verhindern oder beeinträchtigen kann. Ziel des Risikomanagements ist es, in allen Bereichen Risiken zu erkennen und zu dokumentieren, die Auswirkungen zu bewerten und angemessene Maßnahmen zu ergreifen, um die Risiken zu reduzieren.

Zentrale Geschäftstätigkeit ist der Betrieb von IT-Infrastrukturen für Kunden. Die Risikostrategie der Adacor unterliegt daher auch in sich einem risikobasierten Ansatz einem starken Schwerpunkt auf IT-Sicherheitsrisiken und IT-Compliance Risiken.

Die Risikostrategie von Adacor berücksichtigt die Art, den Umfang und die Komplexität der getätigten Geschäfte sowie die Größe, die Personalausstattung und die Organisation von Adacor und leitet sich von der Unternehmensstrategie ab. Die wichtigsten Steuerungsstrategien sind:

- Risikovermeidung (z.B. durch Aufnahme wenig risikorelevanter Geschäftsfelder)
- Risikoübertragung (Versicherungen; Übertragung von Leistungen)
- Risikoverminderung (operative Risikomanagementsysteme)
- Akzeptanz von Risiken (im Rahmen der Risikotragfähigkeit und definierter Risikolimits können Risiken bewusst eingegangen werden)

Zur betrieblichen Risikobeurteilung, also dem Identifizieren und Bewerten von Risiken, hat Adacor ein unternehmensweites Risikomanagement konzipiert, definiert und eingeführt. Im Rahmen der betrieblichen Risikobeurteilung wird Risikomanagement wie folgt durchgeführt:

- Für Unternehmenswerte im zentralen Risikomanagementtool anhand der Szenario- und/oder Schadensmatrix des ISMS entsprechend der ISMS-Leitlinie
- Für Prozesse und Verfahrensanweisungen in der Prozessmodellierung und -definition mit Betrachtung des entsprechenden Business Impacts
- Für neue Anfragen / Kunden im Rahmen des Business Demand Managements mit Betrachtung von Finanz- (Bonität und Investment) und Kundenrisiko (Projekt- und Sponsorqualität).
- Für Lieferanten in der Lieferantenverwaltung mit Betrachtung von Finanzrisiko (Bonität und Volumen) sowie des entsprechenden Business Impacts

Aus diesem Bereich leiten sich folgende wesentliche Kontrollziele und Maßnahmen ab:

KONTROLLZIEL	MAßNAHME
RB-BET-001 - Unternehmensziele Unternehmensziele, die durch Risiken gefährdet sein könnten sind identifiziert und festgehalten.	M1 Unternehmensziele sind im Intranet, Verhaltenskodex und den Leitlinien definiert.
	M2 Die Jahresziele werden von Adacor im Intranet veröffentlicht
RB-BET-002 - Risikomanagement Relevante Risiken werden erfasst und in strukturierten Verfahren bewertet und notwendige Maßnahmen eingeleitet.	M1 Für das Management stehen mehrere Informationsquellen zur Verfügung über identifizierte mögliche Geschäftsrisiken, insbesondere aus den Bereichen Security, Supplier Management und Finance.
	M2 Im Rahmen von Managementmeetings werden erkannte Risiken und Chancen und deren Behandlung besprochen. Dabei werden auch Risiko-Informationen aus anderen Systemen berücksichtigt.
	M3 Die Geschäftsführung wird in ihrer Kontroll-, Steuerungs- und Lenkungsfunction unterstützt durch eine Interne Revision, welche prozessunabhängig agiert und anhand eines risikoorientierten Auditplans eigene Prüfungen durchführt.

4.3 Regeleinhaltung RB-REV

Die Verletzungen der individuellen Unternehmensrichtlinien, vertraglichen Vereinbarungen bzw. gesetzlichen Regelungen stellt ein nicht unerhebliches Risikopotential dar.

Die Einhaltung der Unternehmensrichtlinien und vertragliche Vereinbarungen wird mithilfe eines internen Auditprogramms durch Überprüfungen, Interviews und Kontrollen bzw. mithilfe von Monitoring-Systemen überwacht. Soweit möglich werden Systeme und Prozesse so gestaltet und beschränkt, dass Verstöße gegen Richtlinien erschwert werden.

Verstöße gegen gesetzliche Regelungen werden durch rechtliche Vorabprüfungen von Vorhaben und Verfahren, Unterweisungen und Verpflichtungserklärungen der Mitarbeiter versucht zu verhindern.

Aus diesem Bereich leiten sich folgende wesentliche Kontrollziele und Maßnahmen ab:

KONTROLLZIEL	MAßNAHME
RB-REV-001 - Inter.ne Audits Die Einhaltung von Richtlinien, Regelungen und Gesetzen wird überwacht.	M1 Die Einhaltung von Richtlinien und gesetzeskonformes Verhalten wird durch interne Audits von Adacor regelmäßig überprüft.

RB-REV-002 - Rechtliche Absicherung Rechtliche Anforderungen sind bekannt.	M1 Mitarbeiter haben im Intranet Zugang zu relevanten Gesetzen.
	Bis 31.12.2021: M2 Im Bereich Datenschutz erfolgen jährliche Unterweisungen durch den Datenschutzbeauftragten.
	Seit 01.01.2021: M2 Die Mitarbeitenden werden regelmäßig über für sie bei der Service-Erbringung relevante Regelungen, wozu auch Korruptions- und Geldwäscheprävention gehört unterwiesen und zur Einhaltung dieser verpflichtet. M3 Rechtliche Beratung erfolgt regelmäßig mit Anwälten, dem Datenschutzbeauftragten und Wirtschaftsprüfern.

4.4 Veränderungsmanagement

Veränderungen in den Geschäftsbereichen der Adacor, Weiterentwicklungen in der IT, Änderungen bei Gesetzen, Vorschriften und neue Umweltauflagen können ein Risiko für die Adacor darstellen.

Um diese Risiken zeitnah zu erkennen, strategische sowie operative Maßnahmen ergreifen zu können, integrieren wir uns aktiv in die entsprechenden Themen und Communities indem wir

1. Kontakt zu Behörden wie dem BSI, dem Innenministerium NRW und dem Bundesfamilienministerium aufgebaut haben,
2. spezialisierte Dienstleister in den Bereichen IT-Sicherheit, Datenschutz, ITIL, Routing beauftragt haben uns zu beraten,
3. diverse Fachmedien und Feeds in den Bereichen IT-Sicherheit, Hosting, IT Allgemein, Betriebssystemen und Datenschutz abonniert haben,
4. Mitglied in Fach-Vereinigungen wie der Gesellschaft für Datenschutz und Datensicherheit, RIPE und DeNIC sind.

Aus diesem Bereich leiten sich folgende wesentliche Kontrollziele und Maßnahmen ab:

KONTROLLZIEL	MAßNAHME
RB-VMA-001 - Kontakte und Informationen Informationen zu Veränderungen und Entwicklungen stehen zeitnah zur Verfügung.	M1 Verweis auf Kontrolle IK-INF-002

5. Kontrollaktivitäten auf Prozessebene - KA

5.1 Verständnis

Die im folgenden Abschnitt beschriebenen Kontrollziele und Kontrollen fokussieren sich auf die Prozessebene der wesentlichen Komponenten der Dienstleistungserbringung (siehe 2.2).

Adacor richtet die Dienstleistungserbringung nach den etablierten ITIL Katalogen zum IT Service Management aus. Die Prozesse sind daher nachfolgend entsprechend den ITIL Lifecyclephasen und -Prozessen strukturiert. Die ITIL Kataloge geben Best-Practice Ansätze für Rollen, Funktionen und Prozesse einer IT-Service Organisation.

Die Service Lifecycle Phasen und die dazugehörigen Prozesse sind daher:

Service Design: Ausgestaltung und Definition der Services von Adacor.

- Service Level Management
- Capacity Management
- IT Service Continuity Management
- Information Security Management
- Availability Management
- Supplier Management

Service Transition: Einführung und Anpassungen an Services.

- Change Management
- Service Asset and Configuration Management

Service Operation: Kontinuierlicher Betrieb der Services.

- Incident Management
- Request Fulfillment
- Problem Management
- Access Management

5.2 Service Design

In der Phase des Service Designs werden Kundenanforderungen in Dienstleistungen überführt. Dementsprechend sind hier Prozesse angesiedelt, die die genaue Ausgestaltung der Dienste hinsichtlich z.B. Service Levels, IT-Sicherheit und Verfügbarkeit definieren.

5.2.1 Service Level Management KA-SLM

Der Prozess Service Level Management sichert den Abgleich zwischen den Service Level Anforderungen der Kunden und den Möglichkeiten des Hosting- und Infrastrukturbetriebes von Adacor. Dieser umfasst die komplette Service Level Kette vom Kunden zu Adacor (Service Level Agreements, SLA), innerhalb von Adacor (Operational Level Agreements, OLA) bis hin zu unseren Dienstleistern (Underpinning Contracts, UC).

Allgemein mögliche SLAs und OLAs einzelner Services werden einheitlich und standardisiert definiert und im Servicekatalog festgehalten.

Die Anforderungen der Kunden (Service Level Requirements, SLR) hinsichtlich der Service-verfügbarkeiten, werden im Pre-Sales und Konzeptionsprozess definiert und hier schon hinsichtlich Realisierbarkeit und den Möglichkeiten die Adacor durch die OLAs und UCs gegeben sind bewertet. Erst nach Bewertung und Prüfung der Machbarkeit werden SLRs im Angebot und Vertrag zu verbindlichen Service Level Agreements.

Für die bezogenen Dienste Rechenzentrum, Strom, Kühlung liegen UCs vor, für interne Dienste wie Serversysteme, Service Desk, Reaktionszeiten, Netzwerk, Backup, Internetanbindung existieren OLAs, die die geforderten Service Levels und Verfügbarkeiten definieren. Diese und die Abhängigkeiten der SLAs, OLAs sind im Service Katalog dokumentiert.

Aus diesem Bereich leiten sich folgende wesentliche Kontrollziele und Maßnahmen ab:

KONTROLLZIEL	MAßNAHME
KA-SLM-001 - Service Level Service Level sind intern wie extern definiert und dokumentiert.	M1 Service Level und Operational Level von einzelnen Services werden einheitlich und standardisiert definiert und im Servicekatalog festgehalten.
	M2 Die festgelegten Service Level sind Gesprächsgrundlage und Vorlage für Neuverträge mit Kunden.

5.2.2 Capacity Management KA-CAP

Im Prozess Capacity Management erfolgt die Ermittlung und Überwachung von benötigten Kapazitäten und Performance zur Sicherstellung der mit den Kunden vereinbarten Service Level, sowohl für die allgemeinen übergreifenden Ressourcen als auch für die spezifischen Kundenservices. Das Capacity Management umfasst dabei alle Ressourcen, die zur Service Erbringung notwendig sind, wie z.B. Serverload, Speicherplatz, RZ-Flächen und Netzwerk-Bandbreiten.

Ausbau und Umstrukturierung von Ressourcen, um zukünftige und aktuelle Kapazitätsanforderungen zu erfüllen, ist regelmäßiges Thema in den Meetings der verantwortlichen Fachabteilungen sowie dem Management. In diesem Rahmen laufen alle Informationen, Daten und Kennzahlen aus den Bereichen Infrastruktur, Betrieb, Vertrieb und IT-Sicherheit zusammen und ermöglichen so eine fundierte Planung und Entscheidungsfindung. Speziell im Vertriebsprozess entstehen durch Ausschreibungen oder Beauftragungen adhoc-Anforderungen, sodass Adacor hier einen Prozess etabliert hat, der den Betrieb zeitnah einbindet.

Zur Überwachung der Kapazität und Performance der IT-Systeme betreibt Adacor ein 24/7 Monitoring System in dem alle Server, Netzwerke, Netzwerkkomponenten, Dienste und Applikationen hinsichtlich relevanter Performance und Kapazitätskennzahlen eingebunden sind. Das Monitoring meldet sich bei Überschreitung von definierten Grenzwerten selbstständig per E-Mail und Pagermeldung beim Betriebs- und Infrastrukturteam. Für die Bereitstellung von ausreichend Personalkapazität existieren Regelungen und Personalplanungskalender für die 24/7 Bereitschaft und eine dauerhafte Besetzung des Service Desks während der zugesicherten Zeiten. Die Auslastung der Teams und die Inanspruchnahme von Ressourcen durch die verschiedenen Projekte und Kunden wird durch die Teamleiter und das Management anhand eines Zeiterfassungssystem verfolgt, um bei Bedarf korrigierend eingreifen zu können.

Der zukünftige Bedarf an Kapazitäten wird in relevanten Bereichen durch Prognosetools und regelmäßige Thematisierung in Management- und Teamleitermeetings adressiert. Soweit möglich, versucht Adacor die Prognose durch entsprechende Tools zu unterstützen, die wahlweise Daten zur Bewertung oder direkt Prognosen bereitstellen.

Aus diesem Bereich leiten sich folgende wesentliche Kontrollziele und Maßnahmen ab:

KONTROLLZIEL	MAßNAHME
KA-CAP-001 - Planung und Bereitstellung Benötigte Kapazitäten werden zeitnah geplant und bereitgestellt.	M1 Daten und Kennzahlen zu verschiedenen Kapazitäts- und Performancebereichen stehen in Monitoring-Tools, wie etwa Modulen im XPMS als Entscheidungs- und Bewertungsgrundlage zur Verfügung.
	M2 Maßnahmen zum Capacity Management werden strukturiert eingestellt, priorisiert und umgesetzt.
KA-CAP-002 - Monitoring und Auswertung Die Kapazität und Performance von Ressourcen werden anhand von Kennzahlen kontinuierlich überwacht, ausgewertet und dem Planungsprozess übergeben.	M1 Dienste, Ressourcen und Performancekennziffern von IT-Systemen werden anhand eines Monitoring-System kontinuierlich überwacht und Abweichungen gemeldet.
	M2 Für ausgewählte, relevante Kennziffern sind Tools implementiert, die erlauben den aktuellen und zukünftigen Bedarf zu ermitteln.

5.2.3 IT Service Continuity Management KA-SCM

Im Prozess IT Service Continuity Management (ITSCM) erfolgt die Planung und Bereitstellung von Maßnahmen und Plänen zur Wiederherstellung von IT-Diensten bei Katastrophenszenarien sowie die Planung und der Betrieb von Notfallvorsorgemaßnahmen. In den Bereich ITSCM fallen speziell Redundanzen und Backupmaßnahmen.

Ziel des ITSCM ist zum einen im Katastrophenfall grundlegende Dienste der Hosting Infrastruktur und der Management-Tools planvoll wieder herzustellen und so schnellstmöglich den IT-Betrieb wieder aufnehmen zu können, und zum anderen Kunden eine Infrastruktur bereitstellen zu können, mit der diese bei Bedarf Katastrophenszenarien und Notfallpläne abbilden können.

ITSCM für zentrale Adacor Dienste

Zur Sicherung der IT Service Continuity hat Adacor ein Framework implementiert, das in das Informationssicherheitsmanagementsystem eingegliedert ist. Im Rahmen dessen sind zentrale Systeme und Dienste und deren korrespondierende Risiken identifiziert sowie deren Auswirkung auf die Service-Erbringung gegenüber den Kunden bewertet. Auf Basis dieser Risikoanalysen hat Adacor übergeordnete Maßnahmen in einem Notfallhandbuch und Einzelmaßnahmen in den entsprechenden Betriebshandbüchern im Abschnitt Notfallmanagement definiert.

Als Maßnahmen der Notfallvorsorge betreibt Adacor relevante IT-Systeme (sowie auch alle Kundensysteme) in Rechenzentren, die mindestens der TIER3 Einstufung bei der Stromversorgung entsprechen und nach ISO 27001 zertifiziert sind und so über entsprechenden Redundanzen in den Versorgungsdiensten und Vorsorgemaßnahmen hinsichtlich Elementargefährdungen verfügen. Kritische interne Infrastrukturen sind redundant aufgebaut und geographisch auf verschiedene Brandabschnitte und zwei unterschiedliche Rechenzentren innerhalb Frankfurts verteilt. Digitale Kommunikationswege zum Zugriff auf die Systeme und zur Kundenkommunikation sind redundant über verschiedene Wege und Anbieter eingerichtet. Arbeitsplätze der Systemadministratoren sind mobil und können, z.B. bei Ausfall des Standortes in Offenbach, in das Home-Office oder den Standorten NTT und Essen eingerichtet werden. Interne Systeme werden regelmäßig gesichert und die Backups im Rahmen der Notfallvorsorge an verschiedenen Standorten und Brandabschnitten gespeichert und bei sehr hohem Schutzbedarf auf einem System im Serverraum am Standort Offenbach gespeichert.

ITSCM für Kundensysteme

Die grundlegenden ITSCM Maßnahmen in den Bereichen:

- Redundanz von Versorgungsdiensten
- Redundanz von Internetanbindungen
- Redundante Kommunikationswege
- Vorsorgemaßnahmen gegen Elementargefährdungen

stehen automatisch den Kundensystemen zur Verfügung. Individuelle Redundanzen, Notfallvorsorge und Notfallpläne für dedizierte Kundeninfrastrukturen sind hinsichtlich der Formulierung von Anforderungen, Konzeption und Beauftragung in der Verantwortung des Kunden anzusiedeln. Adacor unterstützt hier das Notfallmanagement seiner Kunden durch die Möglichkeit individuelle Infrastrukturen mit beliebigen Redundanzen und Backupsystemen in verschiedenen Brandabschnitten, Gebäuden oder den beiden getrennten Rechenzentrumsstandorten in Frankfurt aufzubauen.

Aus diesem Bereich leiten sich folgende wesentliche Kontrollziele und Maßnahmen ab:

KONTROLLZIEL	MAßNAHME
KA-SCM-001 - Notfallmanagement Basisdienste Relevante Systeme, Risiken und übergeordnete notwendige Abläufe der Adacor Basisdienste sind identifiziert und dokumentiert.	M1 Notfallmanagement, -vorsorge und -maßnahmen sind im Notfallkonzept definiert und Verantwortungsbereichen zugeordnet.
	M2 Im Rahmen des Risikomanagements werden relevante Dienste und Systeme ermittelt und bewertet und mögliche Schadensszenarien zugeordnet.
KA-SCM-002 - Notfallpläne Basisdienste Notfallpläne für relevante Dienste und Systeme von Adacor Basisdienste sind definiert, dokumentiert, kommuniziert und werden im Rahmen von Notfallübungen getestet.	M1 Maßnahmen und Abläufe sind im Notfallhandbuch und in den Betriebshandbüchern definiert und dokumentiert.
	M2 Die Einhaltung und Effizienz von Maßnahmen und Abläufen des Notfallhandbuchs werden anhand eines Notfallübungsplan getestet.
KA-SCM-003 - Notfallvorsorge Basisdienste Maßnahmen zur Sicherstellung der Verfügbarkeit von betriebskritischen Daten und Systemen der Adacor Basisdienste und zur Aufrechterhaltung des Betriebs zur Erfüllung der SLAs sind implementiert.	M1 Betriebskritische Daten werden im Rahmen eines Backupkonzeptes gesichert. Backups werden auf digitalen Speichersystemen vorgehalten. Daten des XPMS mit sehr hohem Schutzbedarf werden zusätzlich auf einem System am Standort Offenbach gespeichert, welches im Serverraum untergebracht ist. Die Durchführung der Backups wird kontrolliert.
	M2 Produktivsysteme werden in Rechenzentren betrieben, die mindestens über eine TIER3 Einstufung in der Stromversorgung und Schutzmaßnahmen gemäß ISO 27001 gegen Elementargefährdungen verfügen.

	M3 Betriebskritische Systeme und Anwendungen wie XPMS, Passwortmanager, DNS und LDAP werden redundant und als Fallback-Systeme zusätzlich in einem zweiten Rechenzentrum betrieben.
	M4 Arbeitsplätze unserer Systemadministratoren sind grundsätzlich mobil (Notebook, Netbook, Datenkarten) und sind so ortsungebunden.
	M5 Die Standorte der Rechenzentren als auch die Standorte von Adacor sind redundant über verschiedene Provider und physikalische Leitungen an das Internet angebunden. Mehrfache Telefonverbindung über Fest- und Mobilnetz sind als Ausweich- und Alternativ-kommunikationswege implementiert.
	M6: Die relevanten Systeme zur Aufrechterhaltung von Internet- und Telefonverbindungen sind über eine USV vor kurzzeitigen Stromausfällen geschützt.
KA-SCM-004 - Notfallvorsorge Kundensysteme Mit dem Kunden vereinbarte Maßnahmen zur Sicherstellung der Verfügbarkeit seiner Daten und Systeme sind implementiert und überwacht.	M1 Die Funktion von Backupprozessen und Services im Rahmen der Verfügbarkeit (z.B. RAID, Loadbalancing, Stand-By Systeme) werden in Abhängigkeit der kundenindividuellen Vorgaben und Vereinbarungen anhand eines Monitoring-System regelmäßig überwacht und Abweichungen gemeldet.
	M2 Rückspielungs- und Failover tests werden in Abhängigkeit der kundenindividuellen Vorgaben und Vereinbarungen durchgeführt.

Korrespondierende Kontrollen des auslagernden Unternehmens (Kunde)

- Der Kunde trägt die Verantwortung dafür, zu prüfen, dass das gemeinsam erarbeitete Backupkonzept geeignet ist seine Anforderungen an Vorhaltezeit, Frequenz, Datenlücken, Umfang der Daten und Wiederherstellungszeit zu erfüllen.
- Der Kunde trägt die Verantwortung dafür, regelmäßig zu prüfen, ob die Eskalationsstufen und -wege sowie die Maßnahmen zur Katastrophenvorsorge seinen internen Vorgaben und Anforderungen entsprechen.

5.2.4 Information Security Management KA-ISM

Information Security Management ist der Prozess mit dem für die Informationen, Services und IT-Systeme bei Adacor und der Kunden ein angemessener Grad an Sicherheit hinsichtlich Verfügbarkeit, Vertraulichkeit, Integrität und Authentizität geschaffen werden soll. Hierzu hat Adacor ein Informationssicherheits-Managementsystem (ISMS) nach ISO 27001 implementiert. Die Norm definiert international anerkannte Vorgehensweisen zum Aufbau und Betrieb eines ISMS, das auf Basis einer Risikobewertung die Planung, Durchführung, Überwachung, Überprüfung und Verbesserung der Informationssicherheit abdeckt. Das ISMS umfasst die Organisation, Struktur, Verantwortung, Verfahren, Prozesse und Infrastruktur von Adacor und ist in den beiden zentralen Dokumenten Informationssicherheitsleitlinie und ISMS-Leitlinie definiert und beschrieben.

Das ISMS ist bei der Geschäftsführung von Adacor aufgehangen, welche zur Umsetzung, Betrieb und Überwachung des ISMS und der spezifischen Sicherheitsmaßnahmen eine Organisation, bestehend aus dem Informationssicherheitsbeauftragten, dem Informationssicherheitsteam, dem IT-Compliance-Beauftragten und dem Datenschutzbeauftragten, implementiert hat.

Verfahren und Richtlinien

Die Handhabung von Informationssicherheit innerhalb von Adacor wird durch ein Rahmenwerk aus Richtlinien, Sicherheitskonzepten, Verfahrensbeschreibungen, Sicherheitshinweisen und Checklisten eindeutig und verbindlich vorgegeben. Die Vorgaben decken die Bereiche Sicherheitsorganisation, Zutritts-, Zugriffs- und Zugangsschutz, Notfallplanung, Systemhärtung, Informationshandhabung und Administration ab. Die Mitarbeitenden werden regelmäßig in den Regelungen unterwiesen und verpflichten sich auf deren Einhaltung.

Physische Sicherheit

Zur Sicherstellung der physischen Sicherheit an den Standorten von Adacor betreiben wir ein unternehmensweit gültiges Zutrittskontrollkonzept, das die Einteilung und Trennung von Räumen in Sicherheitszonen, die berechtigten Personengruppen, Schließsysteme sowie die vorgegebenen Sicherungsmaßnahmen definiert.

Die operativen Standorte der Systemadministratoren sind durch ein elektronisches Schließsystem, eine Brand- und Alarmmeldeanlage und die Aufschaltung auf eine 24/7 besetzte Leitstelle eines Sicherheitsdienstes gesichert.

Die Erteilung von Zutrittsberechtigungen zu den Standorten von Adacor erfolgt durch die Geschäftsführung durch einen definierten Prozess. Erteilung, Rücknahme und Verlust von Zutrittsberechtigungen werden dokumentiert und die Zutritte zu den Standorten protokolliert.

Für die physischen Sicherheitsmaßnahmen der Rechenzentrumsstandorte sind die beiden RZ-Betreiber Interxion und NTT zuständig. Im Rahmen des Supplier Managements erfolgt eine sorgfältige Definition der erforderlichen Maßnahmen, sowie eine regelmäßige Überwachung und Kontrolle der Rechenzentren und der implementierten Maßnahmen. Beide Rechenzentren verfügen ihrerseits selbst über ein zertifiziertes Sicherheitsmanagement nach ISO 27001.

System- und Datensicherheit

IT-Systeme werden ausschließlich in geeigneten Serverräumen betrieben und sind nach außen durch Firewallsysteme namhafter Hersteller und entsprechend restriktiv konfigurierte Netzwerkkomponenten abgesichert. Über die Firewalls wird eine Netzsegmentierung mithilfe von VLANs vorgenommen, über die die Systeme unterschiedlicher Kunden, Projekte, Fachprozesse oder Sicherheitsstufen logisch getrennt werden. Nicht benötigte Ports und Verbindungen sind sowohl auf den Firewalls als auch auf den Systemen standardmäßig deaktiviert.

Der Zugang zu produktiven IT-Systemen ist (seitens Adacor) auf namentlich benannte Systemadministratoren von Adacor beschränkt (siehe auch Access Management). Diese Berechtigungen werden durch ein standardisiertes Verfahren durch speziell verpflichtete und geprüfte Administratoren vergeben. Für die Zugangsberechtigungen existieren dedizierte Vorgaben und Handlungsanweisungen. Dienste wie Konsole, Webserver und Datenbank werden in Form von Log-Files protokolliert. Normale System-Benutzer haben keinen Zugriff auf diese Log-Files. Fernzugang zu IT-Systemen ist nur über passwortgeschützte, verschlüsselte und authentifizierte Verbindungen möglich (z.B. VPN, IPSec, SFTP).

Für IT-Systeme pflegen wir Betriebshandbücher, die die Zugangsberechtigungen, Befugnisse, Arbeitsanweisungen und Eskalationsmechanismen regeln. Darüber hinaus existieren übergeordnete Sicherheits- und Härtingsrichtlinien, Prozesse und Checklisten für den Umgang mit und die Konfiguration von IT-Systemen.

Arbeitsplatzsysteme von Administratoren verfügen über verschlüsselte Festplatten, automatische Sperren des Desktops, Virenschutz, Desktopfirewalls und Passwortschutz.

Audits, Scans und Kontrollen

Alle Sicherheitsrelevanten internen Systeme bei Adacor werden in regelmäßigen Abständen auf Schwachstellen bei Betriebssystem, Software und Anwendungen überprüft, und gefundene Schwachstellen behoben. Wir verwenden hierzu namhafte und industrieweit anerkannte Schwachstellen-Scanner.

Die Einhaltung der vorgegebenen Sicherheitsrichtlinien und Verfahren wird in Form jährlicher interner Audits und unregelmäßiger externer Penetration-Tests kontrolliert und bei Abweichungen entsprechende korrigierende Maßnahmen ergriffen.

Security Event Management

Externe, durch den Service Desk klassifizierte oder intern gemeldete Security Events werden in einer separaten Queue des Ticketsystems erfasst, durch das Informationssicherheitsteam priorisiert und gesondert bearbeitet.

Als Security Events werden die Ereignisse qualifiziert, aus denen sich nicht nur eine Qualitätsminderung der Services ergibt, sondern aus denen die Gefahr eines konkreten Schadens für Adacor oder der Kunden erwachsen kann, indem

- die Vertraulichkeit personenbezogener Daten und vertraulicher Informationen beeinträchtigt wurde,
- die Integrität von Daten und Systemen beeinträchtigt wurde oder
- durch das Ereignis eine Gefährdung der körperlichen Unversehrtheit von Personen bestehen kann.

Aus diesem Bereich leiten sich folgende wesentliche Kontrollziele und Maßnahmen ab:

KONTROLLZIEL	MAßNAHME
KA-ISM-001 - Verantwortung für Informationssicherheit Informationssicherheit ist als zentrales Element der Geschäftstätigkeit verankert und dies in Leitlinien durch die Geschäftsführung definiert.	M1 Ein Rahmenwerk aus Leitlinien, Konzepten, Richtlinien, Prozessen und Checklisten wurde durch die Geschäftsführung erlassen und regelt den Umgang mit Informationssicherheit, formalisiert und optimiert die internen Abläufe.
KA-ISM-002 - Management und Planung von Informationssicherheit Risiken, Maßnahmen und Verantwortlichkeiten werden in einem umfassenden Managementsystem betrachtet, bewertet, geplant, kontrolliert, verbessert und berichtet.	M1 Ein Informationssicherheitsmanagementsystem nach ISO 27001 ist implementiert. Dies beinhaltet im Speziellen: • Verantwortlichkeiten • Regelungen und Richtlinien • Risikobewertungen • Dokumentation von Assets • Durchführung von Audits • Bewertung und Verbesserung der Maßnahmen M2 Ein Berichtswesen an die Geschäftsführung für erkannte Risiken im Bereich Informationssicherheit ist implementiert. Dies beinhaltet im Speziellen: • Ergebnisse aus internen und externen Audits • Security Events • Status von geplanten Maßnahmen • Veränderungen bei externen und internen Themen • Risikobericht • Möglichkeiten zur kontinuierlichen Verbesserung

KA-ISM-003 - Sicherstellung der physischen Sicherheit Die physische Sicherheit von und der Zutritt zu Adacor Standorten und Informationswerten ist durch Konzepte, Vorgaben und Maßnahmen gesichert und geregelt.	M1 Zutrittskontrolle wird am Standort in Offenbach auf Basis eines definierten Zutrittskontrollkonzeptes durch bauliche und technische Maßnahmen für sicherheitskritische Bereiche erreicht: • Alarmanlage mit Sicherheitsdienst-Aufschaltung • elektronisches Schließsystem • Trennung von Bereichen • automatisch schließende Türen • Zutrittsprotokollierung
	M2 Zutrittsberechtigungen werden durch die Geschäftsführung mittels eines definierten Prozesses erteilt, ausgegeben und dokumentiert.
KA-ISM-004 - Netzwerksicherheit Maßnahmen und Prozeduren zur Absicherung und Kontrolle des Netzwerkzugriffs sind implementiert und dokumentiert.	M1 Der Netzwerkzugriff auf Adacor Netze ist durch technische Maßnahmen beschränkt: • Firewallsysteme • Restriktiv konfigurierte Netzwerkkomponenten • Netzsegmentierung • Deaktivierung von nicht benötigten Ports und Verbindungstypen
KA-ISM-005 - Management von Systemen, Benutzern und Informationen Durch definierte Prozesse, Regelungen, Sicherheitsmaßnahmen und Benutzermanagement wird ein angemessener Schutz für IT-Systeme und Informationen sichergestellt.	M1 Der Schutz von Basissystemen und Administrationsarbeitsplätzen bei Adacor vor Schadsoftware ist im Schutzkonzept gegen Schadsoftware definiert und dokumentiert und die entsprechenden Schutzmaßnahmen: • Firewalls • Zentraler Spamschutz • Lokaler Virenschutz implementiert.
	M2 Fernzugang zu Adacor-internen sicherheitsrelevanten IT-Systemen ist nur über verschlüsselte und authentifizierte Verbindungen möglich.
	M3 Der Zugang zu produktiven IT-Systemen ist seitens Adacor auf namentlich benannte Systemadministratoren von Adacor beschränkt.
	M4 Der Zugang zu Informationen wird über abteilungsbezogene Verzeichnisse definiert. Die Informationen werden hinsichtlich der Vertraulichkeit und Verfügbarkeit klassifiziert und Verantwortlichkeiten inkl. dem berechtigten Personenkreis definiert.

KA-ISM-006 - Security-Tests und - Monitoring Die Funktion der Maßnahmen, Einhaltung von Regelungen, Vermeidung von Schwachstellen und Sicherheitslücken werden durch regelmäßige Audits, Security-Scans und Security-Monitoring-Checks überprüft.	M1 Sicherheitsrelevante oder gefährdete Systeme werden regelmäßig mit Schwachstellen-Scannern geprüft und die Einhaltung von Sicherheitsrichtlinien wird mindestens jährlich in Form interner Audits kontrolliert
KA-ISM-007 Security Event Management Events werden strukturiert qualifiziert und bearbeitet.	M1 Externe, durch den Service Desk klassifizierte oder intern gemeldete Security Events werden in einer separaten Queue des Ticketsystems erfasst, und durch das Informationssicherheitsteam priorisiert und gesondert durch eine dedizierte verantwortliche Person bearbeitet.
	M2 Kritische Sicherheitslücken werden im Rahmen einer Notfallwartung bearbeitet. Hierzu wird durch das SEC-Team ein Change Advisory Board (CAB) einberufen.

Korrespondierende Kontrollen beim auslagernden Unternehmen (Kunde)

- Der Kunde trägt die Verantwortung dafür, dass durch Adacor bereitgestellte und eingerichtete Zugangsdaten und Zugangswege (z.B. VPN, IPSec) vertraulich und sicher behandelt werden und nur qualifiziertem Personal des Kunden zur Verfügung gestellt werden.
- Der Kunde trägt die Verantwortung dafür, schützenswerte Daten und Informationen an Adacor nur über geeignete und sichere Kanäle zu übertragen (z.B. SSL, S/MIME, VPN, PGP).
- Der Kunde trägt die Verantwortung dafür, regelmäßig zu prüfen, dass die IT-Systeme, Dienste und Infrastruktur bei Adacor seinen Anforderungen und internen Vorgaben an IT-Sicherheit entsprechen, sofern die Durchführung einer Sicherheitskonzeption nicht expliziter Vertragsbestandteil ist.

5.2.5 Availability Management KA-AVM

Im Prozess Availability Management sind alle Maßnahmen und Verfahren angesiedelt, die der Sicherung und Erhöhung der Verfügbarkeit von Services und Systemen in Bezug zu den Geschäftsanforderungen von Adacor und operativen Service Level Vereinbarungen dienen. Dies betrifft sowohl bestehende Services als auch die Planung zukünftiger Services intern oder im Rahmen von Transitionsprojekten mit Kunden.

Bei der Planung von neuen Services oder der Anpassung von bestehenden Services wird immer der Einfluss auf die Verfügbarkeit der zugrundeliegenden Infrastruktur und Dienste geprüft. Die Verfügbarkeitsanforderungen von Kunden an die Services werden im Rahmen der Design- und Transitionsphase definiert, geplant und getestet.

Alle Services mit operativen Verfügbarkeitsanforderungen sind mitsamt den zugehörigen Service Levels, IT-Assets, servicespezifischen Verfahren, Eskalationsprozeduren und Ansprechpartnern dokumentiert.

Der Betrieb der IT-Infrastruktur im Rahmen der Service Levels wird durch unser Betriebsteam aus qualifizierten Systemadministratoren durchgeführt. Für den 24/7 Betrieb unterhält Adacor je Bereitschaftskreis eine Rufbereitschaft bestehend aus zwei Administratoren im Aktiv/Backup Modus mit geregelten Übergaben, Technikmeetings und Eskalationsverfahren. Für den Betrieb von IT-Systemen und Services existieren entweder allgemeine oder kundenspezifische Prozessbeschreibungen und Checklisten.

Zur Überwachung der Verfügbarkeit der IT-Systeme wird ein 24/7 Monitoring System betrieben, in dem alle Server, Netzwerke, Netzwerkkomponenten, Dienste und Applikationen eingebunden sind. Ausfälle oder Einschränkungen von Services werden durch entsprechende individualisierte Checks erkannt und dem Betriebs- und Infrastrukturteam gemeldet.

Aus diesem Bereich leiten sich folgende wesentliche Kontrollziele und Maßnahmen ab:

KONTROLLZIEL	MAßNAHME
KA-AVM-001 - Planung von Verfügbarkeit Verfügbarkeitsanforderungen und - Auswirkungen werden bei Changes und Planungen im Vorfeld berücksichtigt.	M1 Bei neuen Projekten und Services werden notwendige Verfügbarkeiten, Eskalationen, Services und deren Monitoring im Rahmen eines Setupprojektes mit dem Kunden (intern oder extern) definiert und eingerichtet.
KA-AVM-002 - Dokumentation von Verfügbarkeiten Verfügbarkeitsanforderungen und relevante Parameter aller kritischen internen Assets sind inventarisiert, dokumentiert und eine entsprechende Sicherheitseinstufung vorgenommen.	M1 Services, Systeme und Zusammenhänge sind im XPMS in der zentralen Configuration Management Database mit allen relevanten Informationen dokumentiert.
KA-AVM-003 - Verfahren zum IT-Betrieb Verfahren und Prozesse zum Betrieb der IT-Systeme und Dienste im Rahmen der Verfügbarkeitsanforderungen sind definiert und implementiert.	M1 Der IT-Betrieb wird durch definierte und dokumentierte Prozesse, Checklisten, Verantwortlichkeiten und Richtlinien für Services und IT-Systeme unterstützt und gesteuert.
KA-AVM-004 - Monitoring von Verfügbarkeiten Alle Verfügbarkeits- und SLA Relevanten Dienste und Systeme werden kontinuierlich überwacht und Vorfälle und Abweichungen gemeldet und dokumentiert.	M1 Dienste und Performancekennziffern werden anhand eines Monitoring-Systems kontinuierlich überwacht und Abweichungen gemeldet. Das Monitoring ist individuell pro Service und System eingestellt und berücksichtigt die individuellen Verfügbarkeitsvorgaben.

Korrespondierende Kontrollen beim auslagernden Unternehmen (Kunde)

- Der Kunde ist dafür verantwortlich die konzipierten und angebotenen IT-Systeme initial und fortlaufend darauf zu hin prüfen, dass diese geeignet sind die Geschäftsziele des Kunden zu erreichen. Alle relevanten Informationen hierzu, die Einfluss auf die Verfügbarkeit der Dienste haben können (z.B. Marketingaktionen oder Systemprüfungen) müssen durch den Kunden mitgeteilt werden.

5.2.6 Supplier Management - KA-SUP

Im Prozess Supplier Management erfolgt die Auswahl, Betreuung und Überwachung von Lieferantenbeziehungen, die aufgrund der Natur der erbrachten Dienstleistung Einfluss auf die Serviceerbringung von Adacor haben. In der Regel betrifft dies Lieferanten in den Bereichen Rechenzentrumsbetrieb, Internetanbindung, Hardware, IT-Sicherheit und Sicherheitsdienste. Regelungen, Verfahren und Abläufe hinsichtlich extern bezogener Leistungen hat die Geschäftsführung in der Sicherheitsrichtlinie Outsourcing definiert und veröffentlicht, die durch entsprechende Tools im XPMS unterstützt werden.

Strategie

Entscheidungen des Supplier Managements werden durch die Geschäftsführung nach sorgfältiger Betrachtung aller relevanten Faktoren getroffen und müssen als geeignetes Mittel gelten, um Engpässe zu beheben, fehlende Kompetenzen auszugleichen oder Zugriff auf hochwertige Leistungen und Infrastrukturen zu erhalten. Adacor verfolgt das Ziel langfristiger, stabiler Lieferantenbeziehungen mit wenigen Dienstleistern in definierten Spezialgebieten.

Prozess

Der Prozess des Supplier Managements gliedert sich in die folgenden Punkte:

1. Identifizierung des Bedarfs i.d.R. aus dem Change- oder Capacity Management heraus
2. Vorauswahl und Überprüfung von Dienstleistern
3. Strategische Entscheidung durch das Management
4. Vertragsschluss
5. Projektumsetzung / Serviceinbetriebnahme
6. Kontrolle

Auswahl & Vertragsschluss

Bei der Auswahl eines Lieferanten werden je nach Business Impact Faktoren wie Referenzen, Finanzen, Kompetenzen, Zertifizierungen und die Prüfung von Notfall- und Sicherheitsmaßnahmen sowie die Vereinbarkeit der Lieferantenbeziehung und deren Ausgestaltung hinsichtlich bestehender Verträge und SLAs geprüft.

Kontrolle

Die Kontrolle der Dienstleister erfolgt mit Methoden, die geeignet sind die relevanten und kritischen Faktoren der Dienstleistung zu überwachen:

- Rechenzentrumsbetreiber in Form von Audits und Auswertung von Dokumentationen.
- Internet-Carrier in Form von Last- und Latenzmonitoring der Anbindung

Aus diesem Bereich leiten sich folgende wesentliche Kontrollziele und Maßnahmen ab:

KONTROLLZIEL	MAßNAHME
KA-SUP-001 - Vorgaben und Richtlinien Mindestanforderungen und Verfahren hinsichtlich Kriterien, Auswahl und Risiko sind definiert, dokumentiert und werden eingehalten.	M1 Die Sicherheitsrichtlinie Outsourcing ist kommuniziert und enthält Vorgaben und Verfahren zum Einkauf von IT-bezogenen Dienstleistungen.
KA-SUP-002 - Vertragsmanagement Verträgen und Vereinbarungen mit Lieferanten durchlaufen sorgfältige rechtliche, finanzielle und sicherheitstechnische Überprüfungen.	M1 Zur Auswahl und Überprüfung von Lieferantenverträgen stehen Checklisten zur strukturierten Prüfung bereit, die die wesentlichen Prüfpunkte hinsichtlich Ablauf, Vertragsanforderungen und IT-Sicherheit enthalten.
	M2 Lieferanten werden im Vorfeld einer Risikobewertung unterzogen, bei denen Business Impact und Servicevolumen betrachtet werden.
KA-SUP-003 - Management von Lieferantenbeziehungen Lieferantenbeziehungen sind identifiziert und Risiken, Konditionen und Verträge werden regelmäßig überprüft.	M1 Lieferanten werden mit relevanten Kennziffern zu Volumen, Risiko und Leistungsdaten im zentralen Lieferantenmanagement gepflegt.
	M2 Die Beziehungen zu als kritisch eingestufte Lieferanten werden regelmäßig einem Review unterzogen.
KA-SUP-004 - Überwachung von Subdienstleistern Die Einhaltung von Leistungs-, Vertrags-, Rechts- und Sicherheitsvorgaben durch RZ-Dienstleister und Internet-Carrier wird überwacht.	M1 Die Performance von Internet-Carriern werden anhand unseres Monitorings kontinuierlich überwacht und Abweichungen gemeldet.
	M2 Unsere Rechenzentrumsdienstleister werden regelmäßig internen Audits unterzogen, bei denen die zugesicherten Leistungen hinsichtlich baulicher-, technischer- und sicherheitstechnischer Maßnahmen sowie die Einhaltung der Sicherheitsrichtlinie für Serverräume überprüft werden.

5.3 Service Transition

Die Phase Service Transition beinhaltet die Prozesse, die benötigt werden, um neue oder geänderte Services (auch Änderungen an bestehenden Services) für einen Kunden in den operativen Regelbetrieb zu überführen.

5.3.1 Change Management - KA-CHA

Im Prozess Change Management wird sichergestellt, dass Changes (Wartung) an IT-Systemen in kontrollierter Weise registriert, geplant, geprüft, autorisiert, priorisiert, durchgeführt und dokumentiert werden. Changes können sowohl durch Kunden als auch intern (z.B. notwendige Sicherheitspatches) angestoßen werden.

Für Changes existieren sowohl grundlegende Prozessdefinitionen über den allgemeinen Ablauf von Changes sowie kunden-, service- oder systemspezifische Prozesse und Checklisten. Weitere benötigte Informationen stehen anhand der CMDB im XPMS (betroffene Systeme, Parameter, Abhängigkeiten, notwendige Informationen) sowie den Projekt- und Kontaktinformationen im XPMS und Betriebshandbuch (Prozesse, Checklisten, Ansprechpartner, Service Levels, Weisungsbefugnisse) zur Verfügung.

Initial wird der Change im Ticketsystem von Adacor registriert. Hierdurch erhält der Change eine eindeutige Ticket (Change) Nummer. Kommunikation des Changes, Auswirkungen, Dauer, Terminvereinbarung, Priorisierung und Freigabe erfolgen dann über das Ticketsystem in enger Zusammenarbeit und Kommunikation mit weisungsbefugten Ansprechpartnern des Servicenehmers.

Changes werden in der Regel unter Berücksichtigung von Checklisten und Prozessen aus dem Projekt / Betriebshandbuch durchgeführt. Änderungen werden so durchgeführt, dass sie, soweit wie möglich, wieder rückgängig gemacht werden können und anschließend sowohl durch Adacor als auch den Servicenehmer auf Funktion geprüft.

Erfolgt nach erfolgreichem Change wird das Ticket geschlossen und die Dokumentation über die CMDB im XPMS der Adacor in Form eines Changelogs, einer Zeiterfassung und der Anpassung der Attribute der betroffenen Systeme durchgeführt. Je nach individueller Kundenvereinbarung erfolgen weitergehende Dokumentationen in Form von Protokollen oder Testreports.

Aus diesem Bereich leiten sich folgende wesentliche Kontrollziele und Maßnahmen ab:

KONTROLLZIEL	MAßNAHME
KA-CHA-001 - Change Prozesse und Informationen Changes werden auf Basis von Prozessdefinitionen, Checklisten sowie der benötigten System-, Service- und Projektinformationen durchgeführt.	M1 Zur Durchführung von Changes sind Prozesse und Checklisten definiert und benötigte Informationen und Beschreibungen stehen in Form der Betriebshandbücher, CMDB und dem Adacor Wiki zur Verfügung.
KA-CHA-002 - Change Handling Changes werden strukturiert erfasst, freigegeben, bearbeitet und dokumentiert.	Bis 31.12.2020 M1 Changes werden vom Helpdesk erfasst und priorisiert. Über das Ticketsystem erfolgt dann die fortlaufende, strukturierte und dokumentierte Kommunikation mit dem Servicenehmer. Die Tätigkeiten und Details des Changes bezüglich Server und Services werden in der Zeiterfassung und dem Changelog dokumentiert. Seit 01.01.2021: M1 Change Anfragen werden vom Helpdesk erfasst und priorisiert. Über das Ticketsystem erfolgt dann die fortlaufende, strukturierte und dokumentierte Kommunikation mit dem Servicenehmer. Bei Änderungen an der technischen Struktur von Serversystemen oder dem strukturellen Aufbau von Software-Bestandteilen im Service werden Tätigkeiten und Details in der Zeiterfassung und dem Changelog dokumentiert.

Korrespondierende Kontrollen beim auslagernden Unternehmen (Kunde)

- Der Kunde ist dafür verantwortlich, Applikationen, die nicht in der Verantwortung der Adacor liegen auf den IT-Systemen zu testen. Insbesondere nachdem Changes (Wartungen) am Betriebssystem durch die Adacor durchgeführt wurden.
- Der Kunde ist dafür verantwortlich zu prüfen, ob geplante und angekündigte Changes zu Konflikten mit den kundenspezifischen Anwendungen führen können und welche besonderen Maßnahmen und Verfahren anzuwenden sind.
- Der Kunde trägt die Verantwortung für die Entwicklung und Betreuung von Anwendungen auf den bei Adacor betriebenen IT-Systeme, sofern vertraglich nichts anderes vereinbart ist.

5.3.2 Service Asset and Configuration Management KA-CON

Im Prozess Service Asset and Configuration Management erfolgt die Bereitstellung aktueller Informationen zur Konfiguration der IT-Infrastruktur und allen an der Serviceerbringung beteiligten Komponenten (Configuration Items) in Form eines Configuration Management Systems (CMS) im XPMS von Adacor.

Hierzu werden im XPMS die Configuration Items in zentralen Datenbanken mit allen relevanten Attributen hinterlegt und Änderungen erfasst. Soll- und Ist-Stand des CMS werden regelmäßig überprüft.

Die Daten des CMS dienen unter anderem als Grundlage für die Betriebshandbücher und Reports der einzelnen Services.

Aus diesem Bereich leiten sich folgende wesentliche Kontrollziele und Maßnahmen ab:

KONTROLLZIEL	MAßNAHME
KA-CON-001 - Configuration Management Database IT-Systeme und Servicekomponenten sind mit ihren jeweiligen Attributen und Changes in einem zentralen System hinterlegt.	M1 Im XPMS ist ein Configuration Management System aufgebaut in dem alle servicerelevanten Systeme und Komponenten sowie Changes erfasst werden.

5.4 Service Operation

Die Phase Service Operation beinhaltet Verfahren und Methoden für den täglichen Betrieb der Services für den Kunden.

5.4.1 Incident Management - KA-INC

Im Prozess Incident Management erfolgt die Behandlung von Störungsmeldungen zu IT-Services (interne Dienste und Kunden-Dienste) mit dem Ziel, auf Störungsmeldungen innerhalb der vereinbarten SLAs zu reagieren und Störungen (Incidents) so schnell wie möglich zu beheben.

Das Incident Management erfolgt durch den Adacor Service Desk, der für die Kunden von Adacor der primäre Ansprechpartner bei Serviceunterbrechnungen ist. Der Service Desk ist für Incident-Meldungen 24/7 an 365 Tagen im Jahr über spezielle Telefon- und Faxnummern sowie E-Mail-Adressen erreichbar. Außerhalb der Bürozeiten von 8-18 Uhr an hessischen Arbeitstagen erfolgt die Service Desk Bereitstellung durch eine Rufbereitschaft bestehend aus zwei Adacor Administratoren je Bereitschaftskreis.

Ein Incident durchläuft im Rahmen des Adacor Incident Managements die folgenden Phasen:

Aufzeichnung

Incidents werden im Adacor Ticket System erfasst und erhalten dadurch eine eindeutige ID. Die weitere Kommunikation und Dokumentation des Incidents erfolgt strukturiert über das Ticketsystem.

Kategorisierung & Priorisierung

Im Ticketsystem wird der Incident einem Kundenservice und einem bearbeitenden Mitarbeiter zugeordnet. Zudem erfolgt die Einstufung und Zuordnung von Priorität, Typ und Eskalationsstufen.

Untersuchung, Lösung und Wiederherstellung

Der verantwortliche Mitarbeiter untersucht den Incident hinsichtlich einer schnellstmöglichen Wiederherstellung der Services. Obwohl es hierbei primär nicht um tiefgehende Ursachenforschung geht, wird eine nachhaltige Lösung gesucht, die die Funktion der Services bis zur endgültigen Problemlösung über das Problem Management sicherstellt. Entsprechende Maßnahmen werden durch den verantwortlichen Mitarbeiter unter Hinzunahme der notwendigen weiteren Service Desk Ressourcen umgesetzt.

Abgrenzung Incident - Change

Wenn der Incident durch einen Defekt ausgelöst wurde und durch die Behebung des Defektes behoben ist, ist der Incident Prozess damit abgeschlossen. Aus der Untersuchung des Incident kann die Notwendigkeit einer technischen Änderung entstehen. Eine Behebung, die den beauftragten Service nicht verändert, kann direkt während der Incident Bearbeitung durchgeführt werden. Sofern eine notwendige Änderung Auswirkungen auf den Umfang des beauftragten Service hat, wird diese in einem separaten Change Request behandelt.

Abschluss

Nach Überprüfung, dass der Incident gelöst wurde, werden die getroffenen Maßnahmen im Ticket dokumentiert und dadurch den Kunden mitgeteilt. Sollten technische Änderungen erfolgt sein, so werden diese in der CMDB dokumentiert

Aus diesem Bereich leiten sich folgende wesentliche Kontrollziele und Maßnahmen ab:

KONTROLLZIEL	MAßNAHMEN
KA-INC-001 - Service Desk Incidents werden durch einen zentralen Service Desk und mithilfe geeigneter Tools entgegengenommen, registriert, dokumentiert, kommuniziert und bearbeitet.	M1 Ein Service Desk zur Entgegennahme von Incident-Meldungen inkl. 24/7 Rufbereitschaft ist implementiert. Einsatzplanung, Aufgaben und Verantwortungen werden dediziert vergeben, kommuniziert und überwacht.
KA-INC-002 - Incident Qualifizierung und Lösung Incidents werden strukturiert qualifiziert und bearbeitet.	M1 Zur Erfassung von Incidents wird ein Ticketsystem betrieben, in dem für jeden Kundenservice Ansprechpartner, Queues, E-Mailadressen und Eskalationsmechanismen implementiert sind. Incidents werden nachvollziehbar im Ticketsystem erfasst.
	M2 Incidents werden im Ticketsystem dediziert einem verantwortlichen Mitarbeiter zugeordnet, einem Kundenservice zugeordnet, priorisiert und typisiert.
KA-INC-003 - Kommunikation und Dokumentation Incidentabläufe und -lösungen werden kommuniziert und dokumentiert. Incidents strukturiert geschlossen.	M1 Die Kommunikation zu einem Incident erfolgt strukturiert und protokolliert über das Ticketsystem. Technische Änderungen an Systemen werden in der CMDB erfasst.

Korrespondierende Kontrollen beim auslagernden Unternehmen (Kunde)

- Der Kunde ist dafür verantwortlich, Incidents zeitnah und vollständig dem Adacor Service Desk zu melden.
- Der Kunde ist dafür verantwortlich, die von Adacor bereitgestellten Incident-, Projekt- und Problem-Reports zu prüfen.
- Der Kunde trägt die Verantwortung dafür, benötigte Reports zu definieren und bei Bedarf anpassen zu lassen und dies bei Adacor zu beauftragen.

5.4.2 Request Fulfillment - KA-RQF

Im Prozess Request Fulfillment erfolgt die strukturierte Abwicklung von **Service Requests** (Anfragen) durch Kunden von Adacor. Ein Service Request kann dabei alle möglichen Varianten von Kundenanfragen beinhalten. Der Prozess stellt dabei sicher, dass Service Requests zeitnah, strukturiert und dokumentiert durch den richtigen qualifizierten Mitarbeiter bearbeitet werden.

Hierzu werden die Service Requests in entsprechenden thematischen oder kundenbezogenen Queues im Adacor Ticketsystem einsortiert und dort durch Mitarbeiter des Service Desks oder des entsprechenden Fachbereichs bearbeitet.

Typische Service Requests bei Adacor sind:

- **Request for Change:** Die typische Anfrage im Rahmen eines Kundenservices an den Service Desk, der nicht ein Incident ist. Requests for Change werden im Rahmen des Change Management weiterbearbeitet.
- **Request for Documentation:** Anfrage bezüglich Anpassung der bei uns hinterlegten Dokumentation.
- **Request for Information:** Anfrage nach Informationen, Daten, Reports oder ähnlichem.
- **Request for Proposal:** Anfrage nach Preisen, Kostenvoranschlägen oder Erweiterungsangeboten.

Aus diesem Bereich leiten wir folgende wesentliche Kontrollziele und Maßnahmen ab:

KONTROLLZIEL	MAßNAHME
KA-RQF-001 - Bearbeitung von Service Requests Service Requests werden zeitnah, strukturiert, qualifiziert und dokumentiert bearbeitet.	M1 Für die Bearbeitung von Service Requests existieren Prozesse auf übergeordneter Ebene zur Einstufung und Verteilung als auch in der Regel requestspezifische Prozesse.
	M2 Service Requests werden vom Helpdesk erfasst, kategorisiert und priorisiert. Über das Ticketsystem erfolgt dann die fortlaufende, strukturierte und dokumentierte Kommunikation mit dem Servicenehmer.

5.4.3 Problem Management KA-PRM

Im Prozess Problem Management erfolgt die nachhaltige Lösung von Problemen sowie die proaktive Analyse von Incidents. Als Problem wird hierbei bei Adacor die Ursache für einen oder mehrere zusammenhängende Incidents bezeichnet. Hierzu erfolgt im Problem Management die Analyse und, in Form von Changes, die Behebung der dem Problem zugrundeliegenden Ursache.

Innerhalb des Problem Managements können die Verantwortlichen entsprechend der Kritikalität des Problems auf weitere Ressourcen von Adacor zurückgreifen.

Identifizierung

Identifiziert der Service Desk die mehrere zusammenhängende Incidents oder die Ursache dafür, wird ein Problem-Ticket eröffnet.

Kategorisierung & Priorisierung

Das identifizierte Problem wird in den jeweiligen regelmäßigen Team-Meetings besprochen. Dabei erfolgt gleichsam eine Priorisierung sowie die Zuordnung zu einem (Kunden)-Service, Fachbereich und verantwortliche Mitarbeitende. Die Kommunikation intern wie extern erfolgt über das Ticketsystem.

Untersuchung und Problemlösung

Die verantwortlichen Mitarbeitenden untersuchen unter Einbeziehung benötigter Ressourcen aus anderen Bereichen oder Teams die Ursache, und versuchen sowohl einen Workaround zur kurzfristigen Verhinderung weiterer Incidents als auch eine nachhaltige Behebung der Ursache zur endgültigen Problemlösung zu erarbeiten und umzusetzen. Technische Änderungen werden, soweit nötig, in der CMDB dokumentiert.

Abschluss

Nach Prüfung, dass das Problem nachhaltig gelöst ist, wird das Problem-Ticket geschlossen und die Lösung kommuniziert.

Aus diesem Bereich leiten sich folgende wesentliche Kontrollziele und Maßnahmen ab:

KONTROLLZIEL	MAßNAHME
KA-PRM-001 - Problemerkassung und Klassifizierung Probleme werden erkannt, erfasst und priorisiert und zugeordnet.	M1 Incidents und Events werden zu Problemen zusammengefasst, Aufgaben werden abgeleitet, dokumentiert und verantwortlichen Mitarbeitenden zugeordnet.

KA-PRM-002 - Problembearbeitung und -Lösung Probleme werden strukturiert durch qualifiziertes Personal unter Einbeziehung aller notwendigen Informationen bearbeitet, dokumentiert und abgeschlossen.	M1 Aufgaben im Rahmen des Problem Management werden von verantwortlichen Mitarbeitenden bearbeitet.
	M2 Mitarbeitende können im Rahmen des Problem Managements auf Ressourcen aus allen Fachbereichen der Adacor zugreifen. In Form der CMDB, Wiki, Checklisten, Monitoring und Prozessdokumentationen stehen notwendige Informationen zur Unterstützung bei der Problemanalyse zur Verfügung.

5.4.4 Access Management - KA-ACM

Der Prozess Access Management ist dafür zuständig autorisierten Benutzern den Zugriff auf Systeme und Informationen zu ermöglichen (Accounts) und dementsprechend auch die Integrität und Vertraulichkeit gegenüber nicht autorisierten Personen zu schützen. Um Zugriffe und Tätigkeiten auf Systemen eindeutig zuordnen zu können, erfordern alle Systeme und Informationen grundsätzlich einen Autorisierungsmechanismus und soweit möglich personalisierte Accounts.

Im Rahmen der Serviceerbringung existieren folgende Accounttypen für Mitarbeiter als auch für Kunden, mit separaten Prozessen:

- VPN-Accounts
- LDAP-Accounts
- System-Accounts
- Ticketsystem-Accounts
- Centreon-Accounts

Die grundlegenden Abläufe der Bearbeitung von Requests im Access Management erfolgt im Rahmen des Request Fulfillment und wird daher nicht erneut beschrieben.

Der Prozess Access Management besteht aus folgenden Schritten:

Anforderung

Die Anfrage wird in Form eines Requests gestellt. Handelt es sich um einen Request für einen LDAP-Account, erfolgt die weitere Bearbeitung ausschließlich durch speziell verpflichtete und geprüfte Administratoren nach einem definierten Verfahren.

Überprüfung

Die Anfrage wird anhand eines Accountspezifischen Prozesses auf Vollständigkeit, Sinnhaftigkeit und Korrektheit durch den zuständigen Adacor Mitarbeiter durchgeführt.

Freigabe

Die Weisungsbefugnis des Antragsstellers wird anhand der Business Service Dokumentation überprüft und sofern diese nicht gegeben ist, die Freigabe durch einen Weisungsbefugten eingeholt.

Rechteerteilung / -entfernung

Anlegen/Anpassen/Löschen des Accounts und Einrichtung/Anpassung/Entfernung der Berechtigungen entsprechend dem Accounttyp-spezifischen Prozess.

Überwachung & Protokollierung

Die Änderungen werden im BHB bzw. in Logs dokumentiert.

Aus diesem Bereich leiten sich folgende wesentliche Kontrollziele und Maßnahmen ab:

KONTROLLZIEL	MAßNAHME
KA-ACM-001 - Identifizierung & Authentifizierung Authentifizierungsmechanismen sind sicher ausgestaltet	M1 Struktur und Vorgaben an das Access Management sind in Form von Leit- und Richtlinien sowie Prozessbeschreibungen definiert und dokumentiert.
	M2 Anforderungen an die Komplexität, Länge, Gültigkeit von Passwörtern sowie die Handhabung sind benutzergruppenspezifisch in den Richtlinien • Sicherheitshinweise für Mitarbeiter • Sicherheitshinweise für Administratoren • Richtlinie IT- und Internetnutzung vorgegeben, dokumentiert und kommuniziert.
KA-ACM-002 - Account Management Die Beantragung, Prüfung, Erteilung, Erweiterung, Einschränkung und Löschung von Zugangsberechtigungen erfolgt strukturiert und dokumentiert.	M1 Die Vergabe von LDAP Berechtigungen ist beschränkt und erfolgt durch speziell verpflichtete und geprüfte Administratoren nach einem definierten Verfahren.
	M2 Änderungen an Zugangsberechtigungen werden zentral und strukturiert im ChangeLog der CMDB bzw. in den entsprechenden AuditLogs dokumentiert.

Korrespondierende Kontrollen beim auslagernden Unternehmen (Kunde)

- Der Kunde ist dafür verantwortlich, berechtigte Personen und deren Weisungsbefugnisse zu benennen und Änderungen bei diesen Personen oder an Zugriffsrechten (z.B. Aufgrund von Kündigungen oder Positionswechseln) der Adacor zeitnah mitzuteilen.

6. Information und Kommunikation - IK-INF

6.1 Verständnis

Information und Kommunikation sind integraler Bestandteil des IKS auf allen Ebenen. Nur wenn die relevanten Informationen zeitgerecht zur Verfügung stehen bzw. intern und extern kommuniziert werden ist ein effektiver Betrieb des IKS möglich.

6.2 Zeitnahe, zuverlässige und relevante Informationen - IK-INF

Informationen mit Relevanz für die Erbringung der Dienstleistung und dem Betrieb des IKS sind aktuell und richtig sowie rechtzeitig verfügbar und zugänglich. Dies beinhaltet auch Informationen zur Beurteilung von (künftigen) Risiken für das Unternehmen. Je nach Art der Informationen findet eine automatische Verteilung an definierte Empfängergruppen oder eine manuelle Bewertung und Verteilung statt.

Als Informationsquellen dienen hierbei:

Externe Informationsquellen:

- Abonnements von Fachzeitschriften
- Abonnements von Newslettern
- RSS-Feeds im XPMS (Intranet)
- Jour Fixes mit Spezialisten
- Kundengespräche und Kundenfeedback
- Fachkonferenzen
- Externe Schulungen und Personenzertifizierungen

Interne Informationsquellen:

- Mitarbeiter-Feedbackgespräche
- Manuelle Reportmöglichkeiten im XPMS
- Automatische Reports via E-Mail
- Regelmäßige Management-, Teamleiter- und Teammeetings
- Audits und Reviews
- Knowledgetools wie Wiki, Changelogs, E-Mailverteiler, Interne Newsletter, Protokolle und Teamchats

Aus diesem Bereich leiten sich folgende wesentliche Kontrollziele und Maßnahmen ab:

KONTROLLZIEL	MAßNAHME
IK-INF-001 - Externe Informationen Informationen aus vertrauenswürdigen Quellen zu aktuellen und zukünftigen Trends und Regularien stehen zeitnah in geeigneter Weise zur Verfügung.	M1 Externe Informationen aus vertrauenswürdigen Quellen werden bevorzugt automatisch oder in Form fester definierter Intervalle bezogen und decken die relevanten technischen, organisatorischen, rechtlichen und betriebswirtschaftlichen Bereiche der Adacor ab: • Fachzeitschriften • Newsletter • RSS Feeds • Fachkonferenzen • Beratung und Schulungen durch externe Fachleute

IK-INF-002 - Interne Informationen Das interne Informationssystem muss relevante Informationen, Reports und Kennzahlen der Serviceerbringung zeitnah den definierten Empfängern bereitstellen um als Basis für Geschäftsentscheidungen und -strategien und -maßnahmen dienen zu können.	M1 Interne Informationen stehen zeitnah, zentral und strukturiert den zur Verfügung und sind geeignet die Entscheidungsfindung zu unterstützen. Hierzu werden: • ein Intranet, bestehend aus zentralen Informationssystemen gepflegt • regelmäßig Stand-Up-, Teamleiter-, Fach-, Team- und Managementmeetings durchgeführt • Informationen in Form interner Newsletter, Feedbackgespräche und Monthlys verteilt
---	--

6.3 Kommunikation von Informationen - IK -KOM

Integraler Bestandteil der Dienstleistungserbringung und des IKS ist die interne und externe Kommunikation. Hierzu hat Adacor in beiden Bereichen eine Kommunikationsstruktur und -infrastruktur geschaffen, die entsprechende zeitnahe, gerichtete und offene Kommunikationswege ermöglicht. Gleichzeitig ist die Verbesserung der Kommunikationsabläufe ein andauerndes Projekt an dem konsequent gearbeitet wird.

Interne Kommunikation

Die internen Kommunikationsstrukturen ermöglichen einen effektiven Austausch von Informationen sowohl up-stream, down-stream zwischen Team- und Leitungsebene als auch cross-stream zwischen Teams und Bereichen. Hierfür wurden z.B. Interne Newsletter, E-Mail-Verteiler, regelmäßige Feedbackgespräche, teamübergreifende Statusmeetings und -Fachgruppen, Daily Stand-Ups, automatische E-Mail Reports und eine Open-Door-Policy der Leitungsebenen implementiert.

Externe Kommunikation

Wichtigster Bestandteil der externen Kommunikation ist die strukturierte, zeitnahe und vollständige Kommunikation mit Kunden und Partnern in der Serviceerbringung. Um dies zu erreichen wird ein umfangreiches Ticketsystem betrieben und im zentralen XPMS für jeden Kunden-Service Ansprechpartner, Eskalationsstufen, E-Mail-Verteiler und Verantwortlichkeiten definiert und dokumentiert. Um die Kommunikation von Abläufen und Begriffen an die Kunden von Adacor anzugleichen, werden immer mehr und mehr Abläufe in Anlehnung an die ITIL Kataloge orientiert.

Aus diesem Bereich leiten sich folgende wesentliche Kontrollziele und Maßnahmen ab:

KONTROLLZIEL	MAßNAHME
IK-KOM-001 - Interne Kommunikation Kommunikation relevanter Informationen erfolgt zeitnah sowohl up-stream, down-stream und cross-stream.	Bis 31.12.2020 M1 Der Austausch service- und risikorelevanter Informationen zwischen den Geschäftsbereichen erfolgt in Form von regelmäßigen 1. Management-Meetings 2. Info-Newslettern der jeweiligen Teams 3. Bereichsübergreifender Meetings 4. SEC-Team Meetings 5. Bereichsübergreifenden Fachgruppen Seit 01.01.2021: M1 Der Austausch service- und risikorelevanter Informationen zwischen den Geschäftsbereichen erfolgt in Form von regelmäßigen - Bereichsübergreifender Meetings und - Info-Newslettern der jeweiligen Teams
	M2 Effektiver und zeitnaher Informationsaustausch zwischen den Hierarchieebenen durch eine Open-Door Policy, Feedbackgespräche und Meetings unter Einbeziehung verschiedener Hierarchieebenen
IK-KOM-002 - Externe Kommunikation Relevante Informationen an Kunden und Partner werden über die vorgegebenen Wege, strukturiert, zeitnah, vollständig, dokumentiert an alle geforderten Empfänger kommuniziert.	M1 Für die Kommunikation mit Partnern sind strukturierte Kommunikationsstrukturen mit zugeordneten Ansprechpartnern und Verantwortlichen in Form von • Rollen • Kommunikationsmatrizen • Service Desk & Rufbereitschaft nach ITIL Best Practices geschaffen.
	M2 Für die strukturierte, nachvollziehbare Kommunikation mit Kunden und Partnern wird ein Ticketsystem genutzt.
	M3 Alle Kommunikation mit Behörden oder staatlichen Stellen wird durch die Geschäftsführung vorgenommen oder durch Mitarbeitende die explizit zur Kommunikation autorisiert wurden.

7. Überwachung des internen Kontrollsystems - ÜW

7.1 Verständnis

Die Überwachung des internen Kontrollsystems in Form laufender oder gezielter Beurteilungen und Audits ermöglicht die Effektivität und Angemessenheit der internen Kontrollen zu beurteilen sowie Anpassungen und Verbesserungen der Kontrollen einzuleiten und umzusetzen.

7.2 Überwachung und Beurteilung von Kontrollen - ÜW-PRF

Die Komponenten des IKS von Adacor werden regelmäßig überwacht um die Wirksamkeit, also die Angemessenheit des Aufbaus (Aufbauprüfung) als auch die kontinuierliche Funktionsfähigkeit (Funktionsprüfung) des IKS als Ganzem zu sichern.

Aufbauprüfung

Die Beurteilung des angemessenen Aufbaus des IKS erfolgt auf Basis von Revisionen. Revisionen finden in regelmäßigen Intervallen statt und werden durch das Management durchgeführt oder das Revisionsergebnis durch das Management geprüft und freigegeben. Bei einer Revision wird überprüft, ob die betrachtete Komponente nach wie vor so gegeben, angemessen und geeignet ist die Unternehmensziele und -Vorgaben zu erreichen. Das Ergebnis und eventuelle korrigierenden Maßnahmen werden im entsprechenden Dokument, Risikomanagement bzw. Richtlinientool im XPMS dokumentiert. Revisionen werden im Rahmen des IKS für folgende Komponenten durchgeführt:

- IKS Dokumentation
- Geschäftsprozesse
- Kontrollziele
- Kontrollen

Funktionsprüfung

Die Prüfung, dass installierte Kontrollen funktionieren und angewendet werden, erfolgt in Form von regelmäßigen, stichprobenartigen internen Audits durch die Abteilung Informationssicherheit & Compliance Management (ISM) von Adacor. Der Prüfungsumfang ist im ISMS-Auditprogramm von Adacor festgelegt. Die Audits und Auditergebnisse werden entsprechend der Richtlinie für interne Audits von Adacor vorbereitet, durchgeführt, dokumentiert, dem Management mitgeteilt und eventuell notwendige korrigierende Maßnahmen festgelegt

Externe Prüfungen

Das IKS wird in seiner Gesamtheit jährlich der Prüfung durch unabhängige Wirtschaftsprüfer unterzogen. Daneben werden besonders Komponenten aus den Bereichen IT-Sicherheit, Datenschutz und Business Continuity unregelmäßig durch externe Prüfer (IT-Sicherheitsfirmen, Wirtschaftsprüfer, IT-Revisoren) im Kundenauftrag auditiert oder bewertet.

Aus diesem Bereich leiten sich folgende wesentliche Kontrollziele und Maßnahmen ab:

KONTROLLZIEL	MAßNAHME
ÜW-PRF-001 - Aufbauprüfung Die Angemessenheit des IKS, der Kontrollziele und Kontrollen zur Erreichung der Business Ziele wird regelmäßig überprüft, die Prüfungen dokumentiert und erforderliche Maßnahmen eingeleitet.	M1 Die IKS Komponenten IKS Dokumentation, Geschäftsprozesse, Kontrollziele und Kontrollen werden einer jährlichen Revision unterzogen.
ÜW-PRF-002 - Funktionsprüfung Die einwandfreie Funktion der installierten Kontrollen muss regelmäßig geprüft werden. Die Prüfungsergebnisse werden dokumentiert.	M1 Im Rahmen des definierten Audit Programms der Adacor wird stichprobenartig die Funktion der Kontrollen durch interne Audits geprüft. Die Auditergebnisse werden dokumentiert und dem Management vorgelegt.

7.3 Korrigierende Maßnahmen - ÜW-KMA

Die in den internen und externen Audits und Revisionen festgestellte Abweichungen und Verbesserungen werden durch das Management von Adacor bewertet und korrigierende Maßnahmen beschlossen.

Die korrigierenden Maßnahmen werden im Managementbericht der Abteilung Informationssicherheit & Compliance Management (ISM) erfasst und in den allgemeinen Task-Management Prozess von ISM zugewiesen.

Die Umsetzung und Wirksamkeit der beschlossenen korrigierenden Maßnahmen werden regelmäßig in den darauffolgenden Revisionen bzw. Folge-Audits überprüft.

Aus diesem Bereich leiten sich folgende wesentliche Kontrollziele und Maßnahmen ab:

KONTROLLZIEL	MAßNAHME
ÜW-KMA-001 - Korrigierende Maßnahmen Notwendige korrigierende oder erweiternde Maßnahmen zur Verbesserung des IKS müssen implementiert werden. Die Umsetzung der Maßnahmen muss verfolgt werden.	M1 Aus den internen und externen Prüfungen werden korrigierende Maßnahmen abgeleitet, die vom Management bewertet und beschlossen werden. Die Maßnahmen werden im Task Management dokumentiert und abgearbeitet.

Anhang A Referenzlisten zu Standards 2021

COBIT5

COBIT	IKS-Kontrollen
Evaluate, Direct, Monitor (EDM)	
EDM-01-BP1	KU-PHI-001
EDM-01-BP2	KU-PHI-001, KU-ORG-002
EDM-02-BP3	KU-REG-001, KU-REG-002, ÜW-PRF-002
EDM-02-BP1	KU-PHI-001
EDM-02-BP2	KU-PHI-001
EDM-03-BP1	KU-REG-002, RB-BET-001
EDM-03-BP2	KU-REG-002, RB-BET-002, RB-VMA-001
EDM-04-BP1	KA-CAP-001
EDM-04-BP2	KA-CAP-001
EDM-04-BP3	KA-CAP-002
EDM-05-BP1	KU-ORG-002
EDM-05-BP2	KU-ORG-002, IK-KOM-002, ÜW-PRF-002
Align, Plan, Organise (APO)	
APO-01-BP1	KU-ORG-001, KU-REG-001, IK-KOM-001
APO-01-BP2	KU-ORG-001

APO-01-BP3	KU-ETH-001, KU-PHI-001, KU-ORG-001, KU-QMA-001, KU-QMA-002
APO-01-BP4	KU-ETH-001, KU-ORG-002, KU-QMA-001, RB-BET-001, KA-SUP-001
APO-01-BP5	KA-ISM-001
APO-01-BP7	KU-ORG-001
APO-01-BP8	KU-ETH-001, KU-REG-002, RB-REV-001, KA-ISM-006
APO-02-BP1	KU-ETH-001
APO-02-BP6	RB-BET-001
APO-05-BP2	RB-BET-002
APO-05-BP3	RB-BET-002
APO-05-BP4	RB-BET-002
APO-05-BP5	KA-SLM-001
APO-07-BP1	KU-PER-001
APO-07-BP2	KU-PER-001, KU-PER-002
APO-07-BP3	KU-PER-001, KU-PER-002
APO-07-BP4	KU-PER-001
APO-07-BP6	KU-PER-001
APO-09-BP1	KA-SLM-001
APO-09-BP2	KA-SLM-001

APO-09-BP3	KA-SLM-001
APO-10-BP1	KA-SUP-002, KA-SUP-003
APO-10-BP2	KA-SUP-001
APO-10-BP3	KA-SUP-002, KA-SUP-003
APO-10-BP4	KA-SUP-003
APO-10-BP5	KA-SUP-004
APO-11-BP2	KU-QMA-002
APO-11-BP3	KU-QMA-001
APO-12-BP1	RB-BET-002, RB-REV-001, KA-CAP-002, KA-ISM-006, KA-AVM-004
APO-12-BP2	RB-BET-002, RB-REV-001, KA-CAP-002, KA-ISM-006, KA-AVM-004
APO-12-BP3	RB-BET-002, KA-ISM-006
APO-12-BP5	RB-BET-002
APO-12-BP6	RB-BET-002, KA-CAP-001
APO-13-BP1	KA-ISM-001, KA-ISM-002
APO-13-BP2	KA-ISM-007
APO-13-BP3	KA-ISM-006
Build, Acquire, Implement (BAI)	
BAI-02-BP1	KA-CAP-002, KA-AVM-001, KA-AVM-002

BAI-02-BP3	KA-AVM-001, KA-AVM-002
BAI-03-BP3	KA-AVM-001
BAI-03-BP4	KA-SUP-002
BAI-03-BP11	KA-SLM-001
BAI-04-BP1	KA-AVM-004
BAI-04-BP3	KA-PRM-002
BAI-04-BP4	KA-CAP-002, KA-AVM-004
BAI-04-BP5	KA-CAP-001
BAI-05-BP5	KA-AVM-003, KA-CHA-001, KA-RQF-001, KA-PRM-002
BAI-06-BP1	KA-CHA-002, KA-RQF-001
BAI-06-BP2	KA-INC-001, KA-INC-002
BAI-06-BP3	KA-CHA-002
BAI-06-BP4	KA-CHA-002, KA-INC-003
BAI-08-BP1	KU-ORG-002, IK-INF-002, IK-KOM-001, IK-KOM-002
BAI-08-BP4	IK-INF-002, IK-KOM-001
BAI-09-BP1	KA-SCM-001, KA-CON-001
BAI-09-BP2	KA-SCM-002, KA-SCM-003, KA-AVM-001
BAI-10-BP1	KA-CON-001
BAI-10-BP3	KA-CON-001
Deliver, Service, Support (DSS)	

DSS-01-BP1	KU-ORG-001, KA-AVM-003, KA-RQF-001, KA-PRM-002, KA-ACM-001
DSS-01-BP2	KA-SUP-003, KA-SUP-004
DSS-01-BP3	KA-CAP-002, KA-SCM-003, KA-AVM-004
DSS-01-BP4	KA-ISM-003
DSS-01-BP5	KA-SCM-003
DSS-02-BP1	KA-ISM-007, KA-INC-002, KA-RQF-001
DSS-02-BP2	KA-ISM-007, KA-INC-002, KA-RQF-001
DSS-02-BP4	KA-ISM-007, KA-INC-002
DSS-02-BP5	KA-INC-003
DSS-02-BP6	KA-INC-003, KA-RQF-001
DSS-03-BP1	KA-PRM-001
DSS-03-BP2	KA-PRM-001
DSS-03-BP4	KA-PRM-002
DSS-04-BP1	KA-SCM-002
DSS-04-BP2	KA-SCM-001
DSS-04-BP3	KA-SCM-003, KA-SCM-004
DSS-04-BP4	KA-SCM-003, KA-SCM-004
DSS-04-BP7	KA-SCM-004
DSS-05-BP1	KA-ISM-006

DSS-05-BP2	KA-ISM-004
DSS-05-BP3	KA-ISM-005
DSS-05-BP4	KA-ACM-002
DSS-05-BP7	RB-REV-001
DSS-06-BP1	ÜW-PRF-001
DSS-06-BP3	KA-ACM-002
DSS-06-BP5	KA-ISM-002
DSS-06-BP6	KU-REG-001, KU-REG-002
Monitor Evaluate Assess (MEA)	
MEA-01-BP-04	ÜW-KMA-001
MEA-02-BP01	RB-REV-001, ÜW-PRF-001
MEA-02-BP02	ÜW-PRF-002
MEA-02-BP03	ÜW-PRF-001
MEA-02-BP04	RB-REV-001, ÜW-PRF-002, ÜW-KMA-001
MEA-02-BP05	KU-REG-001, RB-REV-002, ÜW-PRF-001
MEA-02-BP06	RB-REV-001, ÜW-PRF-002
MEA-02-BP07	RB-REV-001
MEA-02-BP08	RB-REV-001, ÜW-PRF-002
MEA-03-BP01	KU-REG-002, RB-REV-002
MEA-03-BP03	KU-REG-002, RB-REV-001, RB-REV-002
MEA-03-BP04	RB-REV-001

IDW-RS-FAIT-1

reference	IKS Kontrolle
(77)	KU-PHI-001, KU-ORG-001, KU-ORG-002, RB-BET-002, KA-ISM-001, KA-ISM-002
(78)	KU-QMA-002, KA-ISM-001, ÜW-PRF-001, ÜW-PRF-002
(80)	KA-SCM-002

(81)	KA-ISM-001, KA-ISM-002
(82)	KA-SCM-003
(83)	KA-ISM-003
(84)	KA-ISM-005
(85)	KA-SCM-003
(86)	KA-SCM-003
(87)	KA-SCM-001, KA-ISM-007

(88)	KA-SCM-001
(89)	KA-SCM-003
(90)	KA-SCM-003
(91)	KA-SCM-003
(92)	KA-SCM-003
(112)	RB-BET-002

VDA ISA (TISAX)

Nr.	ICS control
1.1	KA-ISM-001
1.2	KA-ISM-008
1.3	KA-ISM-002
5.1	KA-ISM-001, KA-ISM-002
6.1	KA-ISM-001, KA-ISM-002
6.3	KA-ISM-005, KA-ISM-006
6.4	KA-SUP-001, KA-SUP-002, KA-SUP-003
7.1	KU-REG-002, KU-PER-001
7.2	KU-REG-001, KU-REG-002, KU-PER-002
8.1	KA-CON-001, KA-ISM-003
8.2	KA-ISM-002
8.3	KA-ISM-001, KA-ISM-002
8.4	KA-SUP-002, KA-SUP-003
9.1	KA-ACM-001
9.2	KA-ACM-001, KA-ACM-002
9.3	KA-ACM-001
9.4	KA-ACM-001
9.5	KA-ACM-001, KA-ACM-002

9.6	KA-ISM-005
10.1	KA-ISM-002, KA-ISM-005
11.1	KA-ISM-003
11.2	KA-SCM-001, KA-SCM-002, KA-SCM-003
11.3	KA-ISM-003
11.4	KA-ISM-002
12.1	KA-CHA-001, KA-CHA-002, KA-ISM-007
12.2	KA-ISM-004
12.3	KA-ISM-005, KA-ISM-006
12.4	KA-SCM-003, KA-SCM-004
12.5	KA-INC-002, KA-INC-003, KA-CHA-001, KA-ISM-007
12.6	KA-ISM-005, KA-ACM-002, KA-INC-003, KA-CHA-002
12.7	KA-ISM-006, KA-ISM-007
12.8	KA-ISM-006, ÜW-PRF-002
12.9	KA-ISM-002, KA-SUP-003
13.1	KA-ISM-004
13.2	KA-AVM-001

13.3	KA-ISM-004
13.4	KA-ISM-002, KA-ISM-004
13.5	KA-SUP-001, KA-SUP-002, KA-SUP-003
14.4	KA-ISM-002, KA-SUP-001, KA-SUP-003
15.1	KA-SUP-001, KA-SUP-002
15.2	KA-SUP-003
16.1	KA-ISM-007
16.2	KA-ISM-007
17.1	KA-SCM-001
18.1	KU-REG-002, RB-REV-002
18.2	KU-REG-001
18.3	ÜW-PRF-001, ÜW-PRF-002
18.4	KU-REG-001, KU-REG-002, RB-REV-001, RB-REV-002
23.7.2	KU-PER-002, KU-REG-001, KU-REG-002
23.9.2	KA-ACM-001, KA-ACM-002
23.11.1	KA-ISM-003
23.13.3	KA-ISM-004

Annex A der ISO27001:2015

siehe auch Erklärung zur Anwendbarkeit (SoA) zu ISO27001:2015.

control measure of Annex A	ICS-Control
A5.1.1	KA-ISM-001, KA-ISM-002
A5.1.2	KA-ISM-002
A6.1.1	KA-ISM-001, KA-ISM-002
A6.1.2	KA-ISM-001, KA-ISM-002
A7.2.1	KU-PHI-001, KU-ETH-001, KA-ISM-002, RB-BET-002
A7.2.2	KU-PER-002
A7.2.3	KU-PER-001
A7.3.1	KU-PER-001
A8.1.1	KA-CON-001
A9.1.1	KA-ISM-006, KA-ACM-001
A9.1.2	KA-ISM-004
A9.2.1	KA-ACM-002
A9.2.2	KA-ISM-005, KA-ACM-002
A9.2.3	KA-ACM-002
A9.2.5	KA-ISM-005
A9.2.6	KA-ACM-002
A9.3.1	KA-ACM-001

A9.4.1	KA-ISM-004, KA-ISM-005
A9.4.2	KA-ISM-005
A11.1.1	KA-ISM-003
A11.1.2	KA-ISM-003
A11.1.3	KA-ISM-003
A11.1.5	KA-ISM-003
A11.2.2	KA-SCM-003
A12.1.1	KU-ORG-001, KA-AVM-003, KA-CHA-001, KA-RQF-001, KA-PRM-002, KA-ACM-001
A12.1.2	KA-CHA-002
A12.1.3	KA-CAP-002, KA-AVM-004
A12.2.1	KA-ISM-005
A12.3.1	KA-SCM-003
A12.4.1	KA-ISM-006, KA-ISM-007
A12.6.1	KA-ISM-006
A12.7.1	RB-REV-001, KA-ISM-007
A13.1.1	KA-ISM-005
A13.1.2	KA-ISM-004
A13.1.3	KA-ISM-004
A13.2.1	KA-ISM-005
A13.2.2	KU-REG-002, KA-SLM-001

A13.2.3	KA-ISM-005
A13.2.4	KU-REG-002
A14.1.1	KA-ISM-002
A14.1.2	KA-ISM-005
A14.1.3	KA-ISM-005
A15.1.1	KA-SUP-001
A15.1.2	KA-SUP-002
A15.1.3	KA-SUP-002
A15.2.1	KA-SUP-003, KA-SUP-004
A16.1	KA-ISM-007
A17.1.1	KA-SCM-002, KA-SCM-003, KA-ISM-004
A17.1.2	KA-SCM-001, KA-ISM-007
A17.2.1	KA-SCM-003, KA-ISM-004, KA-AVM-001
A18.1.1	RB-REV-002
A18.1.2	KU-REG-002
A18.1.4	KU-REG-001
A18.2.2	KU-REG-002, RB-REV-001, KA-ISM-002, KA-ISM-006
A18.2.3	RB-REV-001, KA-ISM-006

Anhang B Änderungen zur letzten Version 2021

Folgende Kontrollen haben sich im Vergleich zur letzten Version folgendermaßen verändert.

KONTROLLZIEL AUS VORDOKUMENT	ÄNDERUNG	MIT WIRKUNG AB
Einleitung	Redaktionelle Anpassungen	01.01.2021
KU-PER-001	M1 von Checklisten auf Workflows geändert	01.01.2021
RB-REV-002	M2 auf die allgemeinen Compliance-Schulungen bezogen, statt nur Datenschutz	01.01.2021
KA-CHA-002	M1 konkreter beschrieben, dass Tätigkeiten zu Tickets erst dann dokumentiert werden, wenn sie auch stattfanden.	01.01.2021
IK-KOM-001	M1 Dopplung der Bereichsübergreifenden Meetings und Firmenzeitschrift herausgenommen	01.01.2021